

**MILITARY SECURITY AND DEFENSE UNIVERSITY OF THE REPUBLIC
OF UZBEKISTAN
INSTITUTE OF INFORMATION AND COMMUNICATION
TECHNOLOGIES AND MILITARY COMMUNICATIONS
“CYBERSECURITY” DEPARTMENT**

STUDY GUIDE

“Cyber Forensics and Ethical Hacking” course

**TOPIC 1
WINDOWS OS SECURITY**

TOPIC 1

WINDOWS OS SECURITY

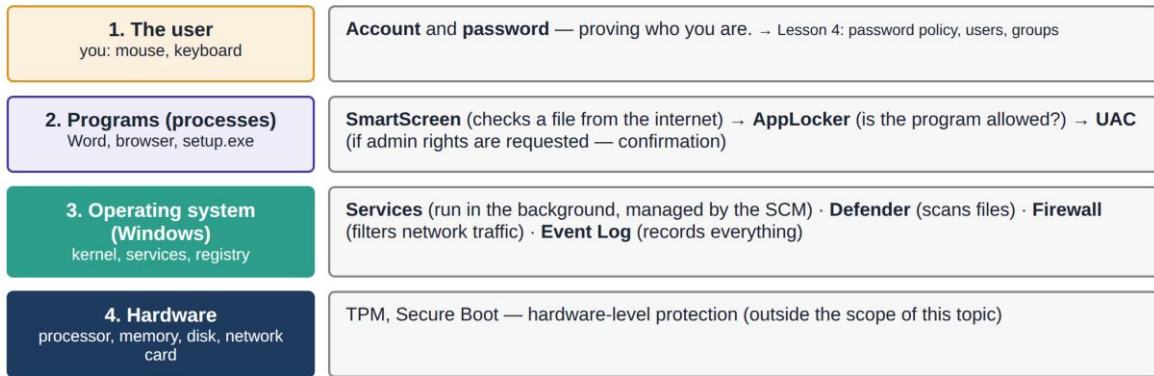
This guide explains all four lessons of the “Windows OS Security” topic (Lesson 1 – lecture, Lesson 2 – seminar, Lessons 3 and 4 – practicals) without requiring any prior knowledge. Each section consists of: (1) a theoretical explanation, (2) a diagram or table that makes it easier to understand, (3) its practical significance, and (4) review questions at the end. A cadet who reads the guide to the end will understand the main security mechanisms of the Windows operating system (services, UAC, AppLocker, SmartScreen, Defender, Firewall, user and security policies) and will be able to configure them in practice.

General structure of the topic

- Lesson 1 (Lecture, 2 hours): Characteristics and functions of services and how to start them;
- Lesson 2 (Seminar, 2 hours): The UAC, AppLocker, SmartScreen, Defender and Firewall security systems;
- Lesson 3 (Practical, 4 hours): Configuring the UAC, AppLocker and SmartScreen security systems in practice;
- Lesson 4 (Practical, 4 hours): Configuring security settings and user security.

Why does this topic matter? In cybersecurity, almost every attack and defense action happens at the operating-system level. Once an intruder gets into a system, the first things they run into are its services and security mechanisms — UAC, Defender, Firewall; conversely, the defender (Blue Team) and the forensic investigator detect the attack precisely through the logs and settings of these same mechanisms. That is why this topic is the foundation for all the following topics (virology, network monitoring, ethical hacking).

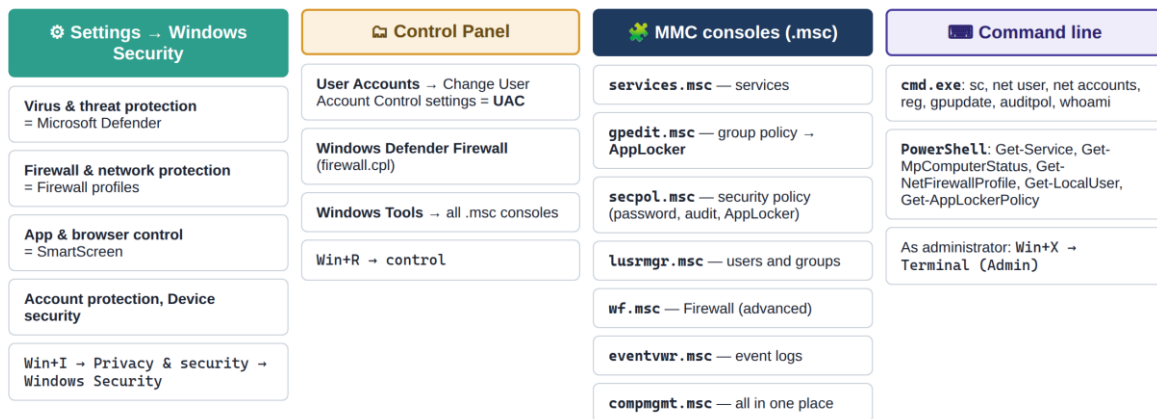
Computer layers and where Windows protection tools work



Each layer has its own “guard” — so even if one layer is fooled, the next one stops the attack (defense in depth)

Figure 1. Computer layers and where Windows protection tools sit

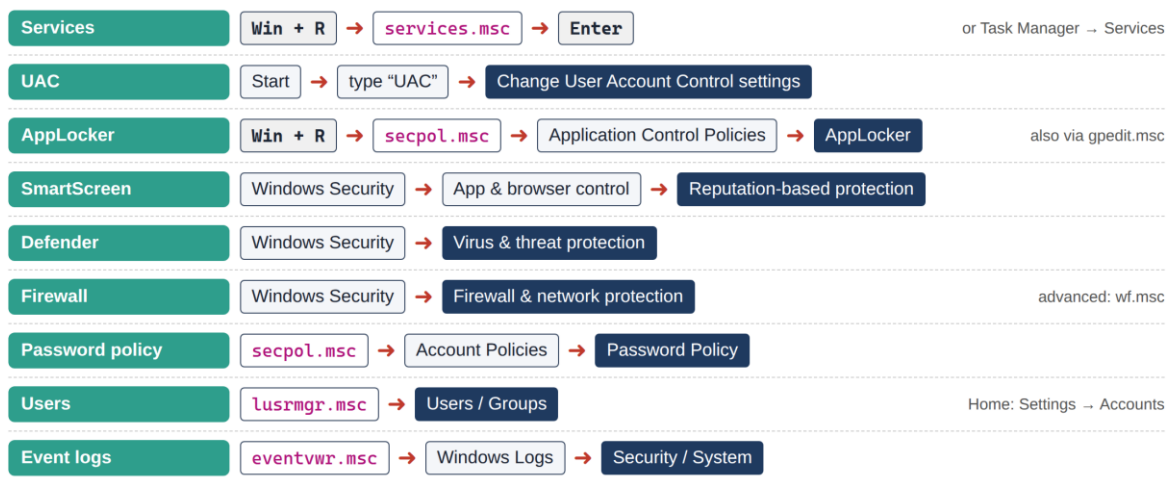
Map of Windows security tools: where are they opened?



All .msc files are located in C:\Windows\System32 — they are “snap-ins” opened inside mmc.exe (Microsoft Management Console)

Figure 2. Map of Windows security tools: where each one is opened

Where each tool is opened: the “click path” diagram



Open the Windows Security app by searching for “Windows Security” in the Start menu; open .msc consoles by typing their name into the Win + R box

Figure 3. The click path to open each tool (diagram)



Figure 4. Training lab layout: virtual machine and snapshots

Contents

Lesson 0. Before you begin: key concepts and preparation

Lesson 1. Windows OS Services (Lecture)

Question 1. Characteristics and functions of services

Question 2. Starting services

Lesson 2. Windows OS Services (Seminar)

Question 1. The UAC, AppLocker and SmartScreen security systems

Question 2. The Defender and Firewall security systems

Lesson 3. Windows OS Services (Practical)

Question 1. Configuring User Account Control (UAC) in practice

Question 2. Configuring AppLocker and SmartScreen in practice

Lesson 4. Windows OS Services (Practical)

Question 1. Configuring security settings (Local Security Policy)

Question 2. Configuring user security

Conclusion

Glossary

References and sources

Lesson 0. Before you begin: key concepts and preparation

This section is the “zero step” before the main topic begins. A student who reads it will know **where to find each tool used in the following lessons, how to open it, and where in Windows it lives**. So later, when names such as **services.msc**, **AppLocker**, **SmartScreen** appear, the question “where did this come from?” will not arise.

0.1. Which editions does Windows come in, and why does it matter?

Windows comes in several editions (**edition**), and they differ in their capabilities. Most importantly, some of the tools in this topic **exist only in the higher editions**. For example, **AppLocker** and **gpedit.msc** (Local Group Policy Editor) **do not exist at all in the Home edition**. That is why you need to know your Windows edition before doing the practical lessons.

To check the edition: press **Win** + **R**, type **winver** and press Enter — the window that opens shows the Windows edition (for example “Windows 11 Pro”).

Which tool is available in which Windows edition?

Tool / feature	Home	Pro	Enterprise / Education	Server
Services (services.msc)	✓	✓	✓	✓
UAC (User Account Control)	✓	✓	✓	✓
Windows Defender antivirus	✓	✓	✓	✓
Windows Firewall	✓	✓	✓	✓
SmartScreen	✓	✓	✓	✓
Local Security Policy (secpol.msc)	✗	✓	✓	✓
Local Group Policy (gpedit.msc)	✗	✓	✓	✓
AppLocker	✗	partial	✓	✓
Domain / Active Directory GPO	✗	✗	✓	✓

To find your edition: **Win** + **R** → **winver**. AppLocker works fully only in the Enterprise/Education and Server editions.

Figure 5. Which security tool is available in which Windows edition

Recommendation for the lab

To complete this topic in full, **Windows 11 Pro or Enterprise** is recommended (in a virtual machine). The Home edition has no **secpol.msc**, **gpedit.msc** or **AppLocker**, so some tasks in Lessons 3 and 4 cannot be done on it.

0.2. The five “doors” for configuring Windows

In Windows, a single setting can often be reached in several ways. These ways fall into five main groups — once you know them, you can find any tool:

- **MMC consoles (.msc files):** “deep” settings such as services, security policy and logs. To open: **Win** + **R** → for example `services.msc`.
- **The Settings app:** modern, simplified settings (user accounts, updates). To open: **Win** + **I**.
- **Control Panel:** the classic control panel (Firewall, User Accounts). To open: **Win** + **R** → `control`.
- **The Windows Security app:** all protection tools in one place (Defender, Firewall status, SmartScreen). To open: search the Start menu for `Windows Security`.
- **Command line (PowerShell / cmd):** for automation and quick actions (`sc`, `net user`, `gpupdate`).



The same setting can often be reached through several doors. This guide shows the most convenient path for each tool.

Figure 6. The five main ways (“doors”) to configure Windows

0.3. What are MMC and “.msc”? Why do all consoles look the same?

In the following lessons, names such as `services.msc`, `secpol.msc`, `gpedit.msc`, `eventvwr.msc`, `lusrmgr.msc` come up often. All of them are built on one common base — **MMC (Microsoft Management Console)**. MMC is an empty “frame” into which a module called a **snap-in** is loaded. Each `.msc` file is a ready-made console prepared with exactly one snap-in.

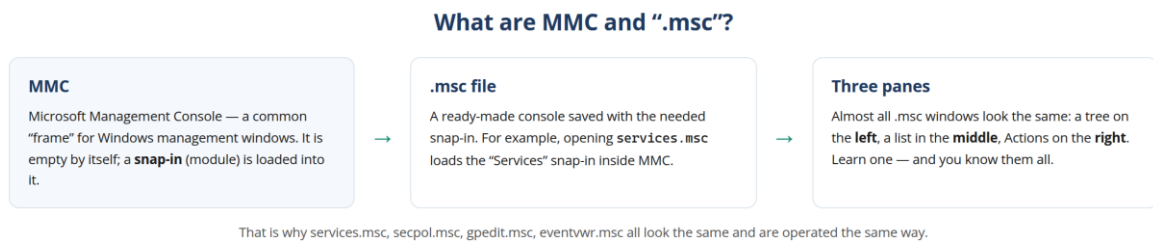


Figure 7. MMC, the “.msc” file and the three-pane layout

Almost all **.msc** windows have **the same three-pane layout**: on the left — the tree of sections, in the middle — the contents of the selected section, on the right — the actions (Actions). Once you learn one, the others look familiar too.

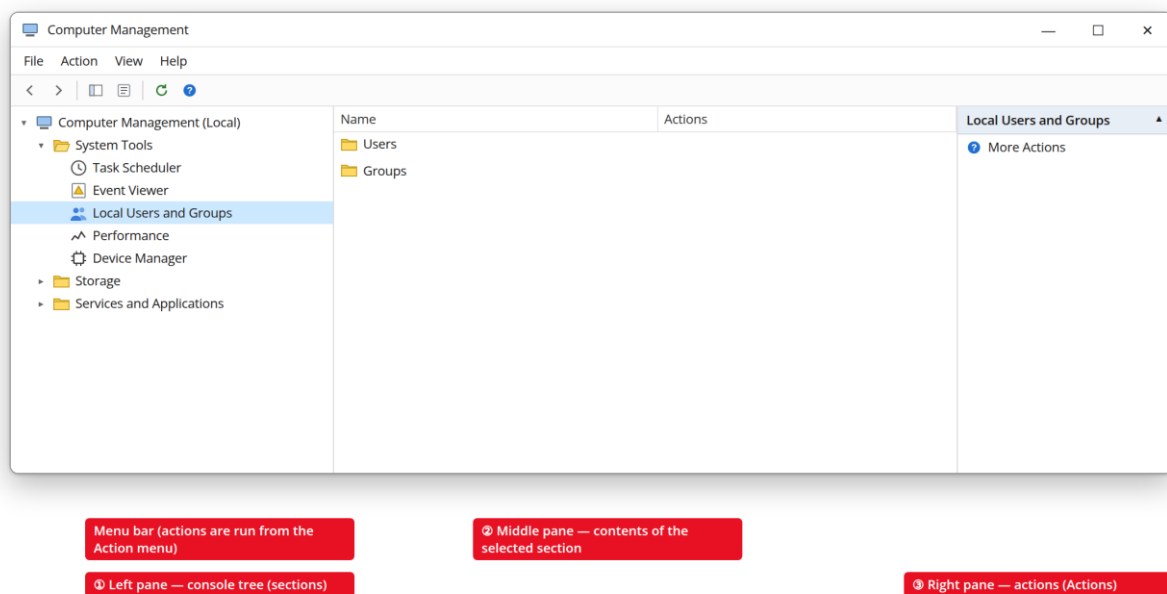


Figure 8. The three panes of an MMC console (Computer Management example)

0.4. The Run box and Start search — the two keys that open everything

90% of the tools in this guide are opened in one of two ways. The first is **the Run box**. Pressing **Win + R** opens a small window; you type the name of a program or console into it and press Enter.

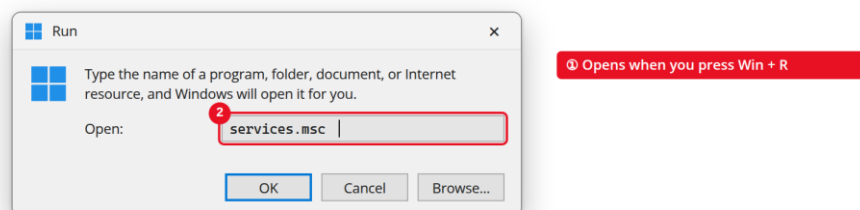


Figure 9. The Run box (Win + R) — the console name is typed into it

The second is **Start menu search**. Press the **Win** key and start typing the name of what you are looking for; Windows shows the matching result. This is especially handy when you do not know the exact console name (for example “User Account Control”).

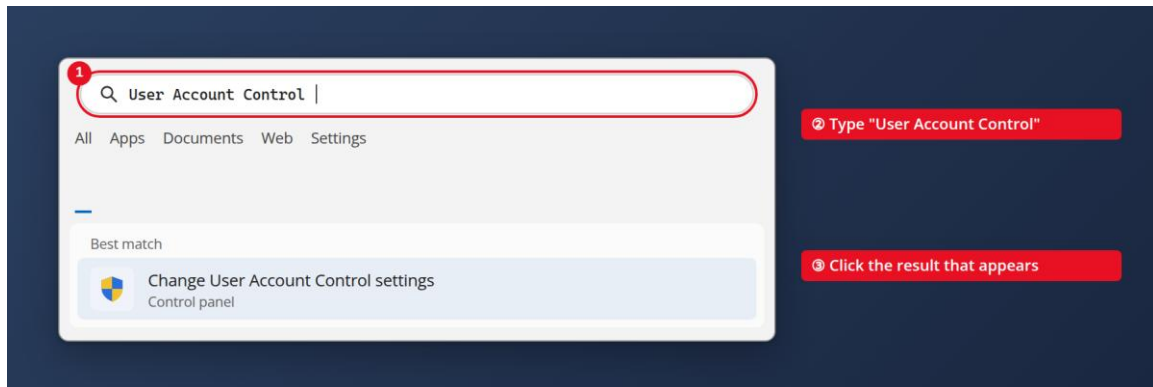


Figure 10. Finding a setting through Start menu search

0.5. Opening with administrator rights (Run as administrator)

Most security settings require **administrator rights**. If you open them with ordinary rights, the settings appear “greyed out” (cannot be changed) or an error appears. So open PowerShell or any other tool via **right-click** → “**Run as administrator**”. A **UAC** confirmation window will then appear — this is normal.

Remember

If you see “Access is denied” or the buttons are greyed out, the cause is usually the same: the tool was opened **without administrator rights**. Close it and open it again as administrator.

0.6. Getting to know the Windows Security, Control Panel and Settings apps

These three apps are the places you will open most often in the following lessons. It is useful to look at them in advance.

Windows Security — the Defender antivirus, Firewall status and SmartScreen live in this app. Open it by searching the Start menu for **Windows Security**.

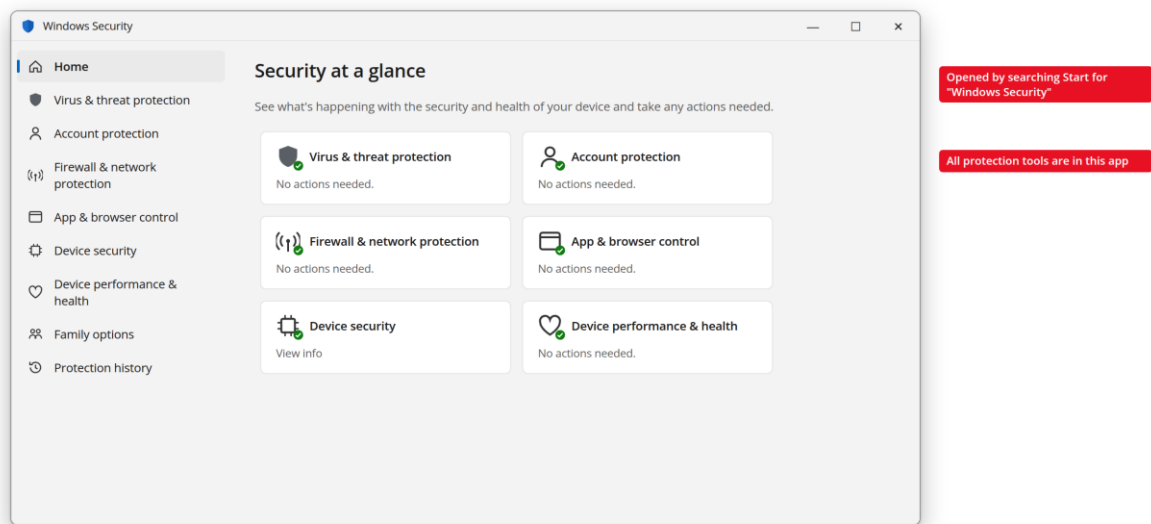


Figure 11. The home screen of the Windows Security app

Control Panel — the classic control panel. Windows Firewall and User Accounts (UAC) are opened from here. **Win** + **R** → **control**.

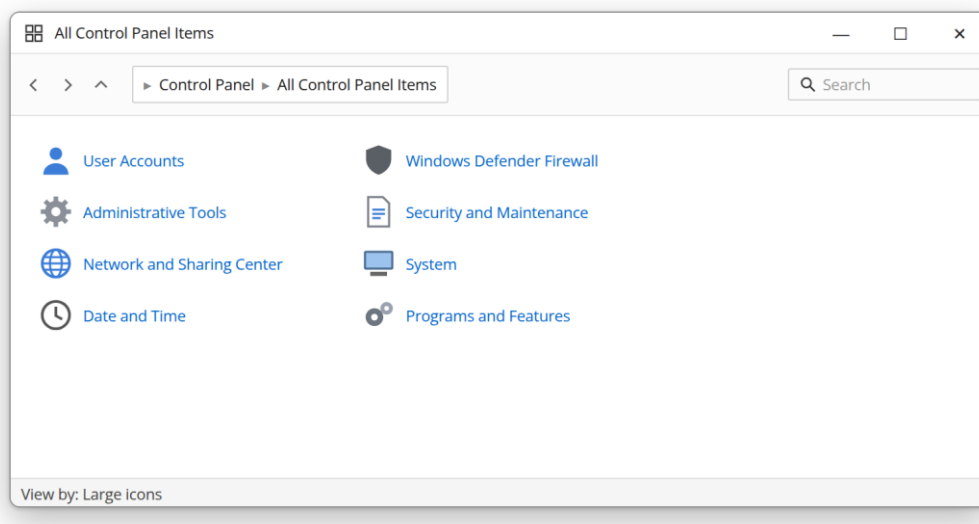


Figure 12. Control Panel (all items, large icons view)

Settings — the modern settings app. User accounts and updates are here. **Win** + **I**.

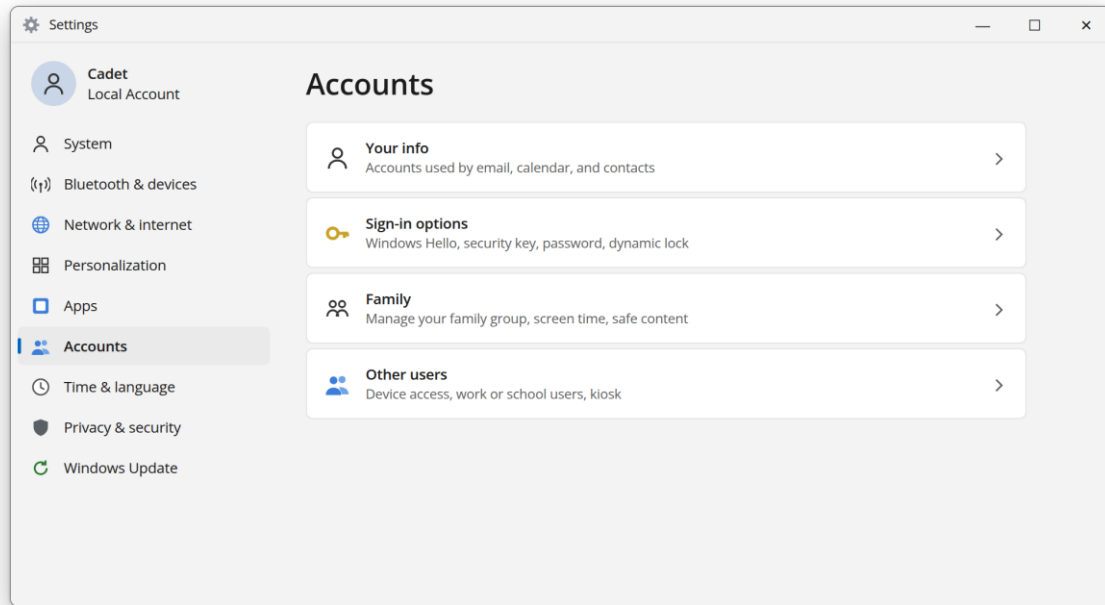


Figure 13. The Windows 11 Settings app (Accounts section)

Lesson 0 summary

Now you know: Windows editions differ; settings are reached through five doors; **.msc** consoles all work the same way; **Win + R** and Start search are the main keys; security settings require administrator rights. With this knowledge, the following lessons are much easier to master.

Lesson 1. Windows OS Services (Lecture)

Topic: Windows OS Security **Lesson type:** Lecture **Duration:** 2 hours

Learning questions

1. Characteristics and functions of services
2. Starting services

Question 1. Characteristics and functions of services

1.1. What is a Windows service?

Every computer runs two kinds of programs: the first are ordinary programs you open with the mouse and whose window you see on screen (for example Word, a browser). The second are programs you do not see, which have no window on screen but constantly run in the background. This second kind is called a service.

A service differs from an ordinary program in three main ways:

1. **It runs without a user:** a service can run even when nobody has logged in — for example, if you turn on the computer and do not sign in to any account, dozens of services are still running in the background.
2. **It starts automatically:** it starts as soon as Windows boots, without the user doing anything.
3. **It runs under special system accounts:** whereas an ordinary program runs in the name of your account, a service usually runs under special, highly privileged accounts such as SYSTEM, LocalService or NetworkService.

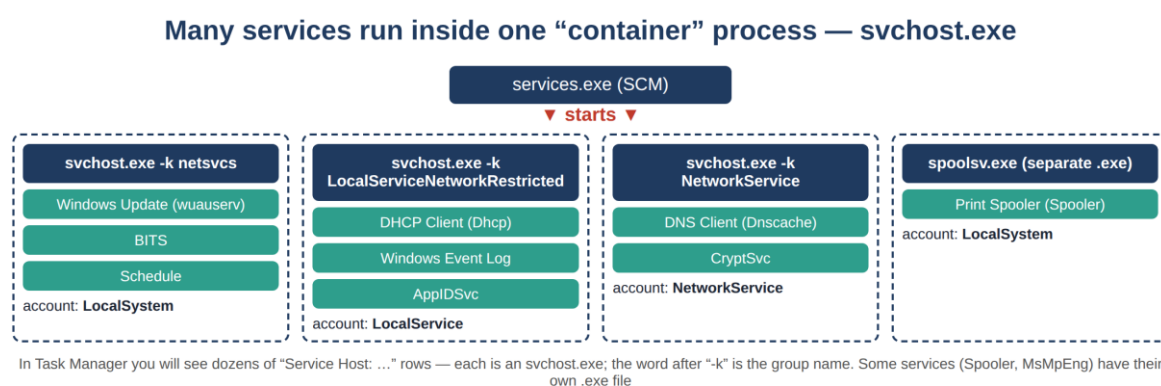


Figure 14. Services and svchost.exe processes

1.2. Why does this matter for cybersecurity?

This is the most important point of the whole topic and must be understood well. Services deserve special attention from a security point of view for three reasons:

4. **High privilege.** Many services run at the SYSTEM level — the highest privilege level in Windows, with even more rights than an administrator. If an attacker takes control of such a service, they can take full control of the entire computer through it.
5. **A persistence tool.** Once malware gets into a computer, it wants to keep running even after the computer restarts. The most reliable way to do that is to register itself as a new service, because services start automatically when Windows boots.
6. **A privilege escalation path.** If a service is misconfigured (for example, if an ordinary user can also write to its file), a low-privileged attacker can climb all the way up to SYSTEM level through that weakness. The best known of these cases is the “unquoted service path” vulnerability, which is officially listed in the MITRE ATT&CK knowledge base as technique T1574.009.

How the “unquoted service path” vulnerability works (MITRE ATT&CK T1574.009)

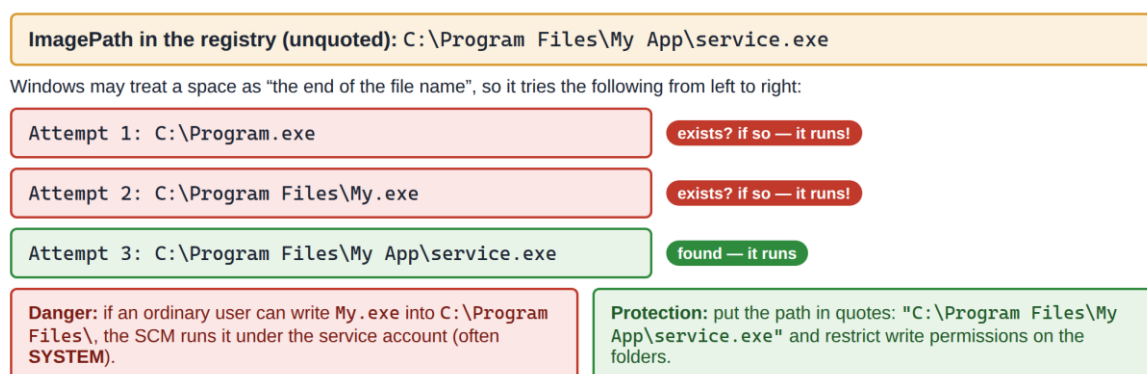


Figure 15. How the “unquoted service path” vulnerability works (diagram)

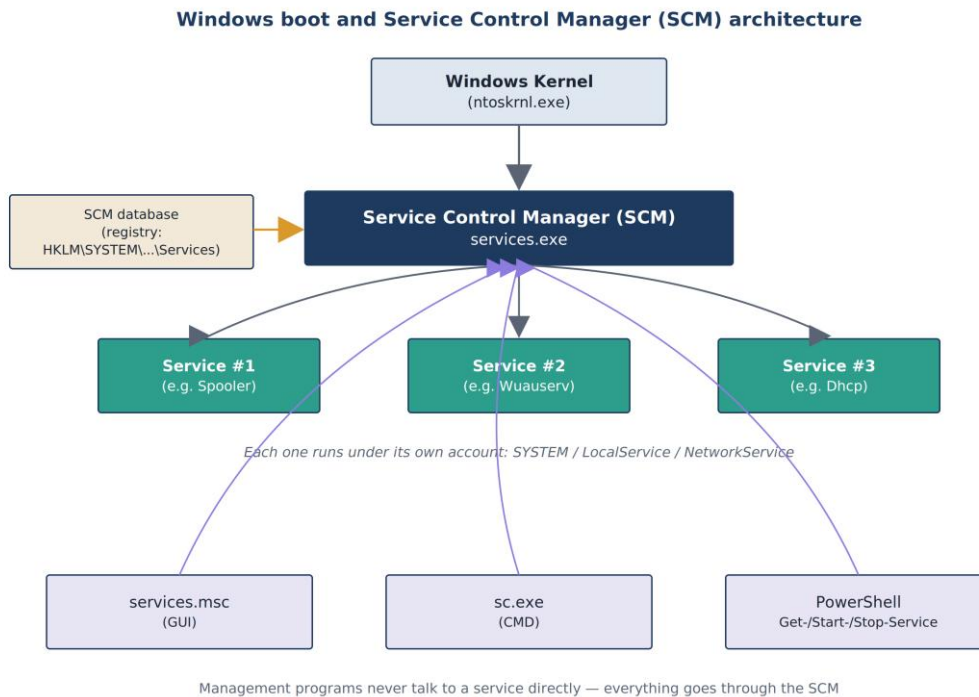


Figure 16. Windows boot and the Service Control Manager (SCM) architecture

1.3. Service Control Manager (SCM) — the “supervisor” of all services

Windows has hundreds of services, and it is impossible to control each of them individually. That is why there is a special central component — the Service Control Manager (SCM). It runs as the `services.exe` file and starts automatically as soon as Windows boots. The SCM performs the following tasks:

7. It keeps the database of all installed services and driver services (this data is stored in the Windows registry, specifically under the `HKLM\SYSTEM\CurrentControlSet\Services` key).
8. It starts each service at system boot or on request.
9. It continuously tracks the state (running/stopped) of the running services.
10. For each service it defines who has the right to access it (the security descriptor).

Note that no management program (`services.msc`, `sc.exe`, PowerShell) talks to a service directly — everything goes through the SCM. Thanks to this centralized architecture, Windows services can be managed securely even remotely.

The SCM database: structure of a service key in the registry

	Value name	Type	Example (Spooler)	Meaning
	ImagePath	REG_EXPAND_SZ	%SystemRoot%\System32\spoolsv.exe	path of the file that is started
	Start	REG_DWORD	2	0 Boot, 1 System, 2 Automatic, 3 Manual, 4 Disabled
	ObjectName	REG_SZ	LocalSystem	account it runs under
	DisplayName	REG_SZ	Print Spooler	name shown in services.msc
	Type	REG_DWORD	0x110	service type (own process, interactive)
	DependOnService	REG_MULTI_SZ	RPCSS, http	which services must run first
	DelayedAutostart	REG_DWORD	1	if present — Automatic (Delayed Start)

Every change made by services.msc, sc.exe or PowerShell is actually written into these values. To open the Registry Editor: Win + R → regedit

Figure 17. Structure of a service key in the registry (HKLM\SYSTEM\CurrentControlSet\Services)

What does the registry key mentioned above actually look like? To see it, open **Win** + **R** → **regedit** (with administrator rights) and go to the **HKLM\SYSTEM\CurrentControlSet\Services** key. Each service is stored here as a separate key.

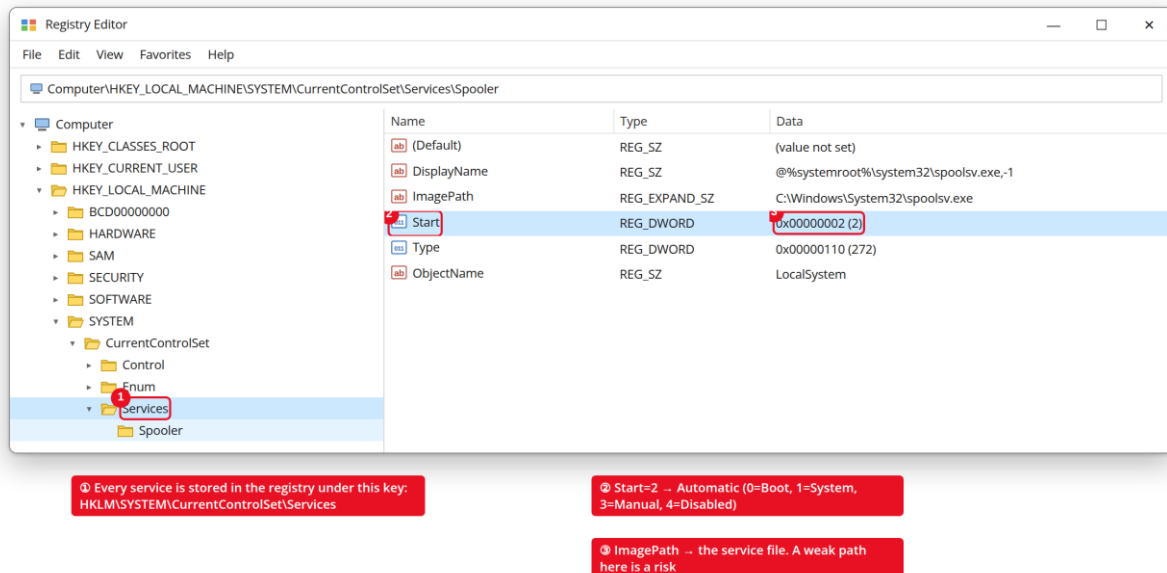


Figure 18. regedit — a service key and its values (annotated)

The **Start** value here corresponds to the **Startup type**: 2 = Automatic, 3 = Manual, 4 = Disabled (0 and 1 are for driver services). **ImagePath** is the path to the service file — if exactly this path is written incorrectly, the **unquoted service path** vulnerability arises.

1.4. The service life cycle (Service States)

During its life, every service goes through several states. Understanding them is important for diagnostics and troubleshooting: for example, if a service stays in the “START PENDING” state for a long time, that indicates a problem.

Service life cycle (Service States)

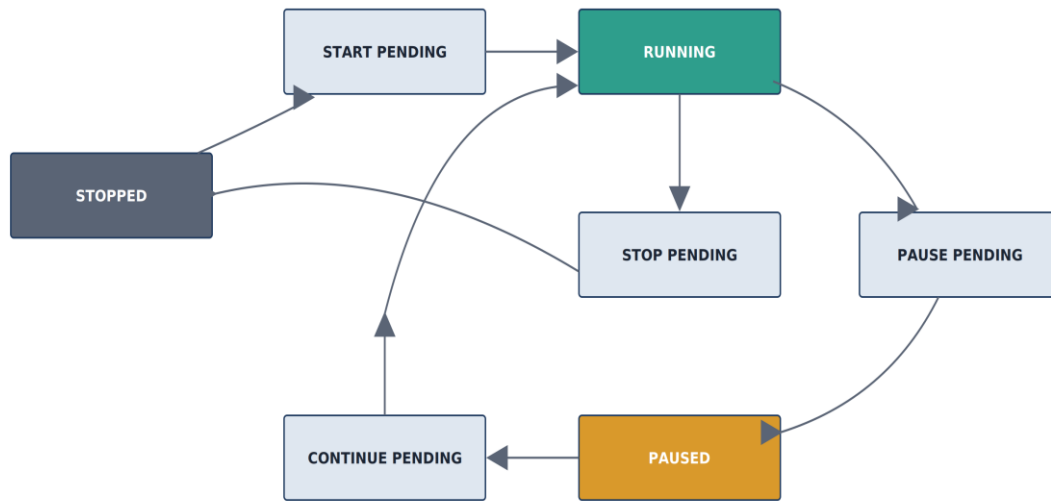


Figure 19. The service life cycle (Service States)

State	Meaning
Stopped	The service is fully stopped and not running.
Start Pending	The service is in the process of starting (not fully started yet).
Running	The service is fully running.
Pause Pending	The service is in the process of being paused.
Paused	The service is temporarily suspended but stays in memory and can resume quickly.
Continue Pending	The service is in the process of resuming from pause.
Stop Pending	The service is in the process of stopping.

1.5. Startup types (Startup Type)

For each service it is specified separately when it should start. This setting is called the “startup type” and it is very important from a security point of view: switching unused services to “Disabled” is one of the simplest ways to reduce the attack surface.

Type	Meaning	When it is used
Automatic	Starts immediately at system boot, before everything else.	For important services that are always needed (for example networking, Windows Update).
Automatic (Delayed Start)	Starts a little later, after the system has finished booting.	For services that are needed but not immediately — speeds up the boot.

Type	Meaning	When it is used
Manual	Starts only when another program or the user requests it.	For rarely used services (for example Print Spooler, if the printer is rarely used).
Disabled	Does not start at all, even when requested.	For unused services that may be dangerous from a security point of view.

1.6. Which account does a service run under?

Every service runs “in the name of” a particular user account and has that account’s rights. Windows has three special built-in accounts for services:

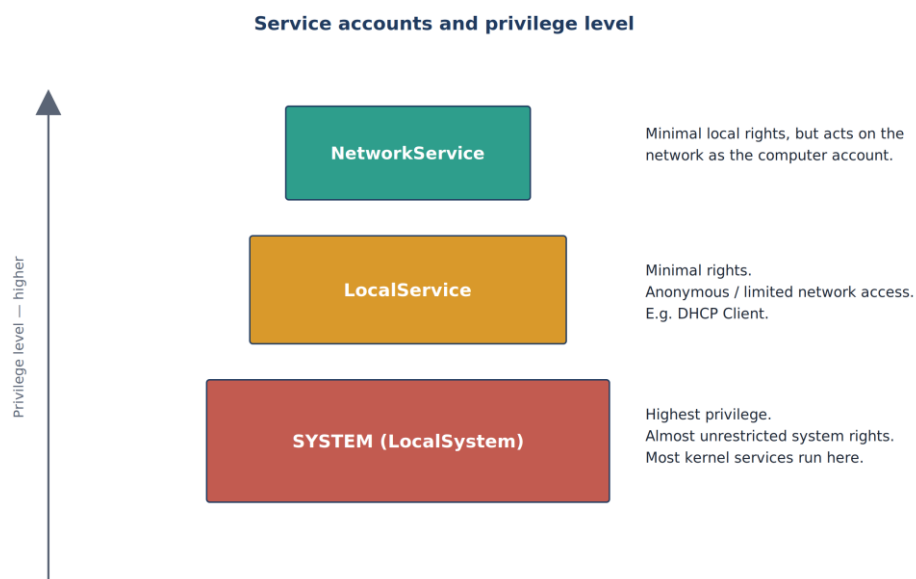


Figure 20. Service accounts and their privilege level

Account	Privilege level	Network access	Example
SYSTEM (LocalSystem)	Highest — almost unrestricted	As the computer account	Many kernel and system services
LocalService	Minimal, local only	Anonymous / very limited	Low-privilege services such as DHCP Client
NetworkService	Minimal locally, but active on the network	As the computer account	Some network-facing services

Keep in mind from a security point of view

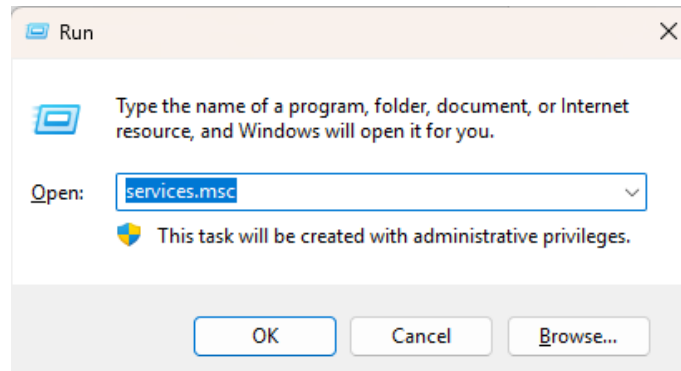
- A service running with SYSTEM rights is the most “valuable prize” for an attacker, because capturing it means controlling the whole system.
- Always follow the “least privilege” principle: the fewer rights a service is given, the higher the security.

Question 2. Starting services

There are three main tools for managing Windows services: the graphical interface (services.msc), the command-line tool (sc.exe) and PowerShell. As we saw above, all three talk to the Service Control Manager in the background.

2.1. Through the GUI — services.msc

11. To open it: press the **Win + R** keys, type services.msc in the window that opens and press Enter.



12. The window that opens shows the list of all services, their status (Running / Stopped), their startup type, and in the “Log On” column which account each one runs under.

A closer look at the services.msc window — what do the columns mean?

The thing that raises the most questions for beginners is the columns in the **services.msc** window. Below are the real window and the meaning of each column.

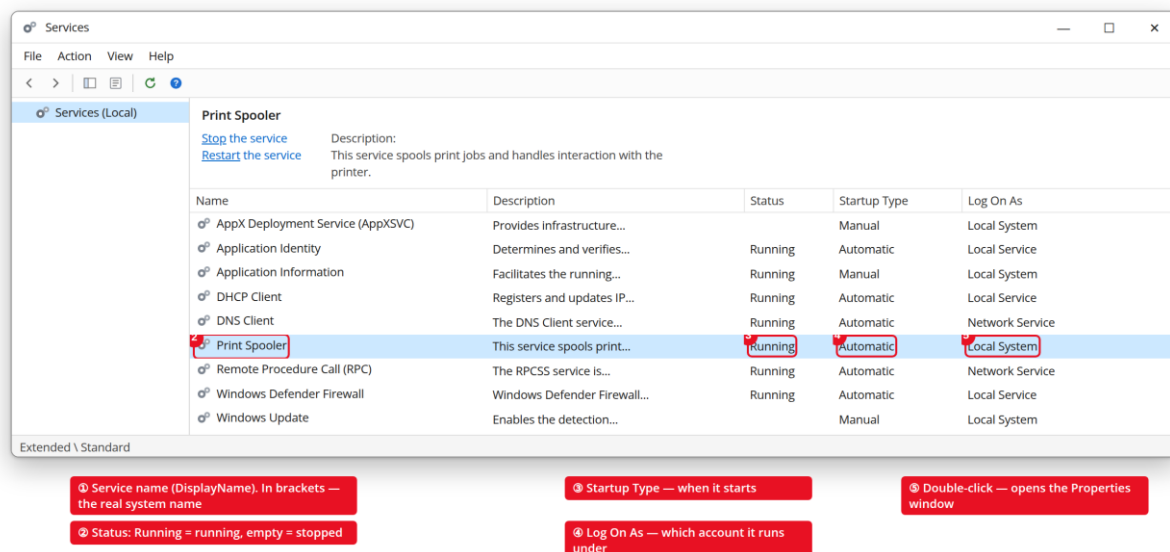
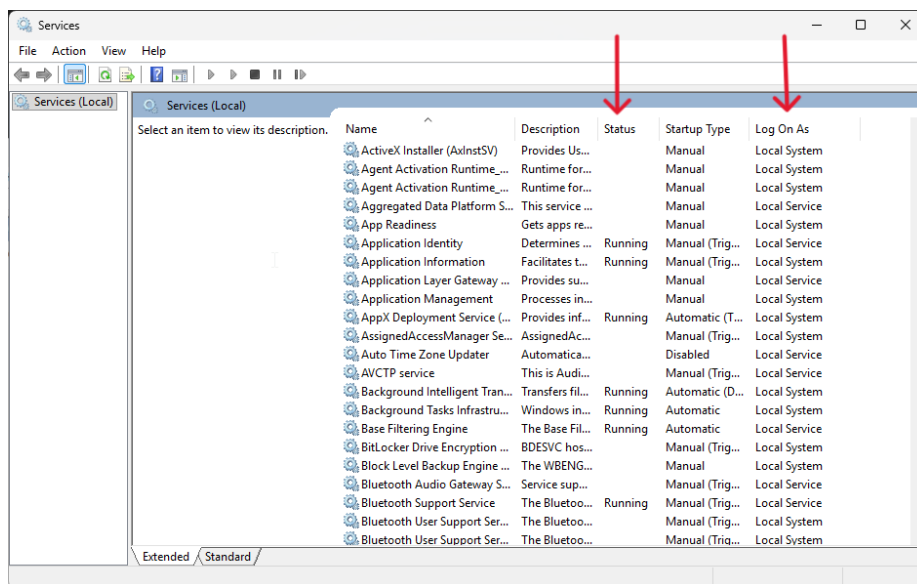


Figure 21. The services.msc window and the meaning of its columns (annotated)

Column	What it means
Name	The visible name of the service (DisplayName). In brackets — the internal system name (for example Spooler).
Description	A short description of what the service does.
Status	Running = it is running; empty or Stopped = it is stopped.
Startup Type	When it starts: Automatic, Automatic (Delayed), Manual, Disabled.
Log On As	Which account the service runs under (Local System, Local Service, Network Service).

At the bottom of the list there are the **Standard** and **Extended** tabs. In **Extended** mode, an extra description of the selected service and the “Stop / Restart” links appear on the left.



- By double-clicking a service (or right-click → Properties) you can change its Startup type, and stop or start the service.

The service Properties window — this is where you configure it

Double-clicking a service opens the **Properties** window. The most important tab is **General**: this is exactly where the **Startup type** is changed and the service is **Start / Stop**-ped.

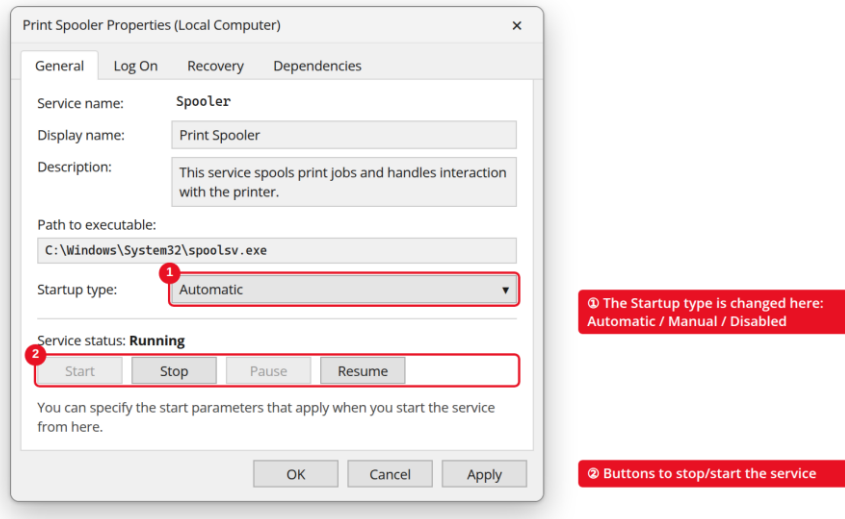


Figure 22. Service Properties → General tab (annotated)

The second important tab is **Log On**: here you see which account the service runs under. **Local System account** is the highest privilege; “This account” lets you switch it to another account.

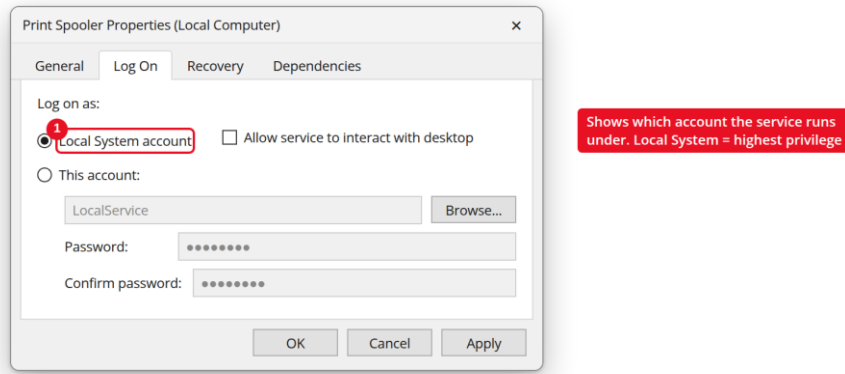


Figure 23. Service Properties → Log On tab

Besides services.msc, there is another quick way to view services: **Task Manager** (**Ctrl** + **Shift** + **Esc**) → the **Services** tab. The PID (process ID) is also shown here.

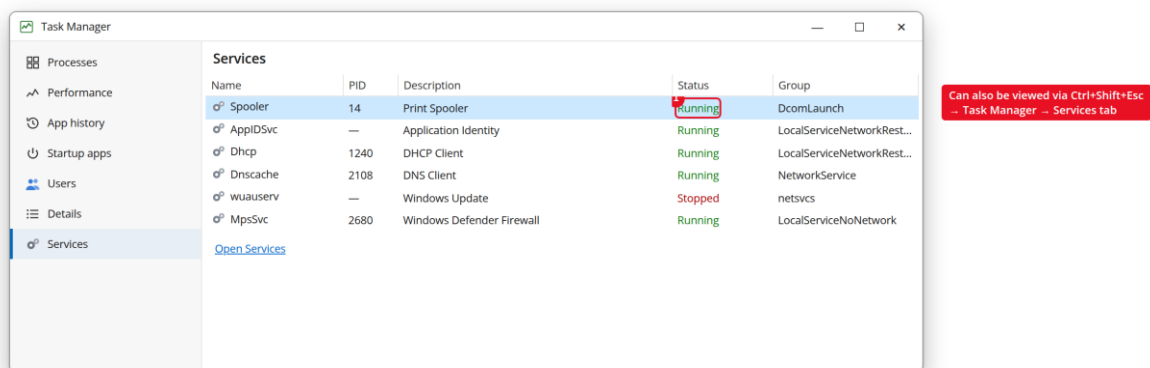
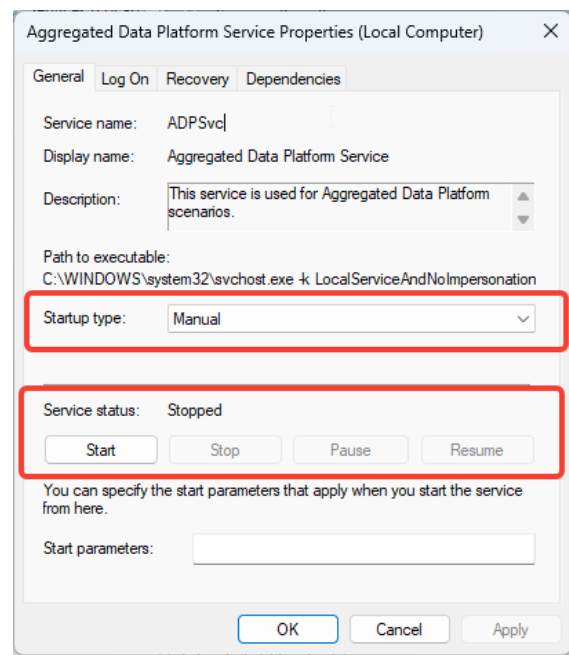
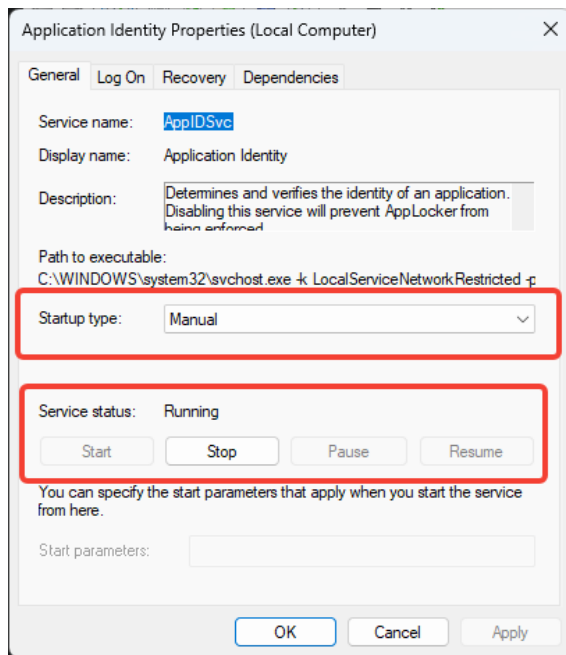


Figure 24. Task Manager → Services tab



2.2. From the command line — sc.exe

sc (Service Control) is the classic Windows tool for managing services from the command line. The most frequently used commands:

Command	What it does	Standard user	Administrator
sc query <servicename>	Shows the current state of the service	Works	Works
sc start <servicename>	Starts the service	Does not work	Works
sc stop <servicename>	Stops the service	Does not work	Works
sc config <servicename> start=disabled	Changes the startup type to “Disabled”	Does not work	Works
sc qc <servicename>	Shows the service configuration (including the file path) — important in security audits	Works	Works

```
C:\Users\user>sc query Spooler
SERVICE_NAME: Spooler
        TYPE               : 110  WIN32_OWN_PROCESS (interactive)
        STATE                : 4    RUNNING
                        (STOPPABLE, NOT_PAUSABLE, IGNORES_SHUTDOWN)
        WIN32_EXIT_CODE       : 0    (0x0)
        SERVICE_EXIT_CODE   : 0    (0x0)
        CHECKPOINT           : 0x0
        WAIT_HINT            : 0x0
```

```
C:\Users\user>sc stop Spooler
SERVICE_NAME: Spooler
        TYPE               : 110  WIN32_OWN_PROCESS (interactive)
        STATE                : 1    STOPPED
        WIN32_EXIT_CODE       : 0    (0x0)
        SERVICE_EXIT_CODE   : 0    (0x0)
        CHECKPOINT           : 0x0
        WAIT_HINT            : 0x0
```

<pre>C:\Users\user>sc start Spooler</pre> <pre>SERVICE_NAME: Spooler TYPE : 110 WIN32_OWN_PROCESS (interactive) STATE : 2 START_PENDING (NOT_STOPPABLE, NOT_PAUSABLE, IGNORES_SHUTDOWN) WIN32_EXIT_CODE : 0 (0x0) SERVICE_EXIT_CODE : 0 (0x0) CHECKPOINT : 0x0 WAIT_HINT : 0x7d0 PID : 4068 FLAGS :</pre>	<pre>C:\Users\user>sc config Spooler start= disabled</pre> <pre>[SC] ChangeServiceConfig SUCCESS</pre> <pre>C:\Users\user>sc qc Spooler</pre> <pre>[SC] QueryServiceConfig SUCCESS</pre> <pre>SERVICE_NAME: Spooler TYPE : 110 WIN32_OWN_PROCESS (interactive) START_TYPE : 4 DISABLED ERROR_CONTROL : 1 NORMAL BINARY_PATH_NAME : C:\WINDOWS\System32\spoolsv.exe LOAD_ORDER_GROUP : SpoolerGroup TAG : 0 DISPLAY_NAME : Print Spooler DEPENDENCIES : RPCSS : http SERVICE_START_NAME : LocalSystem</pre>
<pre>C:\Users\user>sc config Spooler start= auto</pre> <pre>[SC] ChangeServiceConfig SUCCESS</pre> <pre>C:\Users\user>sc qc Spooler</pre> <pre>[SC] QueryServiceConfig SUCCESS</pre> <pre>SERVICE_NAME: Spooler TYPE : 110 WIN32_OWN_PROCESS (interactive) START_TYPE : 2 AUTO_START ERROR_CONTROL : 1 NORMAL BINARY_PATH_NAME : C:\WINDOWS\System32\spoolsv.exe LOAD_ORDER_GROUP : SpoolerGroup TAG : 0 DISPLAY_NAME : Print Spooler DEPENDENCIES : RPCSS : http SERVICE_START_NAME : LocalSystem</pre>	

Learning to read the sc query output

```
SERVICE_NAME: Spooler
        TYPE               : 110  WIN32_OWN_PROCESS (interactive)
        STATE                : 4  RUNNING
                        (STOPPABLE, NOT_PAUSABLE, ..)
        WIN32_EXIT_CODE       : 0  (0x0)
        SERVICE_EXIT_CODE   : 0  (0x0)
        CHECKPOINT           : 0x0
        WAIT_HINT            : 0x0
```

TYPE — 10: own process; 20: shared inside svchost; 100 added: interactive. 1 or 2 — driver

STATE — 1 STOPPED, 2 START_PENDING, 3 STOP_PENDING, 4 RUNNING, 5 CONTINUE_PENDING, 6 PAUSE_PENDING, 7 PAUSED

WIN32_EXIT_CODE — 0 means no error. 1077 — the service has never been started; 5 — access denied

CHECKPOINT / WAIT_HINT — in a "...PENDING" state the service tells the SCM "I am still working, wait this long"

Figure 25. Meaning of the fields in the sc query output

Below are the real outputs of the `sc` commands above. `sc qc` shows the full service configuration:

```
Administrator: Windows PowerShell
PS C:\Windows\system32> sc qc Spooler

[SC] QueryServiceConfig SUCCESS

SERVICE_NAME: Spooler
        TYPE               : 110  WIN32_OWN_PROCESS (interactive)
        START_TYPE          : 2  AUTO_START
        ERROR_CONTROL       : 1  NORMAL
        BINARY_PATH_NAME    : C:\Windows\System32\spoolsv.exe
        LOAD_ORDER_GROUP    : SpoolerGroup
        TAG                 : 0
        DISPLAY_NAME        : Print Spooler
        DEPENDENCIES        : RPCSS
                        : http
        SERVICE_START_NAME  : LocalSystem

PS C:\Windows\system32>
```

`sc qc` — the service configuration. `BINARY_PATH_NAME` and `SERVICE_START_NAME` matter in a security audit

Figure 26. `sc qc` output — `BINARY_PATH_NAME` and `SERVICE_START_NAME` (annotated)

`sc query` shows the current state (STATE) of the service:

```

Administrator: Windows PowerShell
PS C:\Windows\system32> sc query Spooler

SERVICE_NAME: Spooler
        TYPE               : 110  WIN32_OWN_PROCESS (interactive)
        STATE                : 4      RUNNING
                               (STOPPABLE, PAUSABLE, ACCEPTS_SHUTDOWN)
        WIN32_EXIT_CODE       : 0      (0x0)
        SERVICE_EXIT_CODE    : 0      (0x0)
        CHECKPOINT            : 0x0
        WAIT_HINT             : 0x0

PS C:\Windows\system32>

```

STATE: 4 RUNNING — the service is running. (1 STOPPED, 2 START_PENDING, ...)

Figure 27. `sc query` output — meaning of the `STATE` field

2.3. With PowerShell

PowerShell is the modern tool and the most convenient one for automation. The main commands (cmdlets):

Cmdlet	What it does
<code>Get-Service</code>	Shows the list of all services
<code>Get-Service -Name "Spooler"</code>	Shows the state of one specific service
<code>Start-Service -Name "Spooler"</code>	Starts the service
<code>Stop-Service -Name "Spooler"</code>	Stops the service
<code>Set-Service -Name "Spooler" -StartupType Disabled</code>	Changes the startup type

And this is how the PowerShell command `Get-Service` works — a filter has been added to show only running services:

```

Administrator: Windows PowerShell
PS C:\Windows\system32> Get-Service | Where-Object Status -eq "Running" | Select-Object -First 6

Status Name                DisplayName
-----
Running AppIDSvc          Application Identity
Running AppInfo          Application Information
Running Dhcp              DHCP Client
Running Dnscache          DNS Client
Running MpsSvc            Windows Defender Firewall
Running Spooler           Print Spooler

PS C:\Windows\system32>

```

Figure 28. PowerShell — viewing running services with `Get-Service`

2.4. How is this knowledge used in practice?

From the point of view of cyber forensics and ethical hacking, this knowledge is applied in two directions:

- Defense (Blue Team):** identifying unnecessary, unused services and switching them to “Disabled” reduces the attack surface. For example, if the computer has no printer, it is recommended to disable the Print Spooler service.

15. **Attack and analysis (Red Team / Forensics):** after getting into a system, an intruder often creates a new service and uses it to establish persistence. That is why checking `sc query` or the registry Services key is one of the first steps in a forensic analysis.

Additional important information

Below are several important system services you will often meet in practice, and what they do — you will need to know them in the following lessons (especially for security settings):

Service name	What it does
Windows Update (wuauserv)	Downloads and installs security and other updates for the system
Print Spooler (spooler)	Queues and manages print requests
DHCP Client (dhcp)	Lets the computer obtain an IP address from the network automatically
DNS Client (dnscache)	Caches requests that translate domain names into IP addresses
Remote Procedure Call (RpcSs)	A core service required by many system components
Windows Defender Antivirus Service	Provides real-time protection against malware
Windows Firewall (MpsSvc)	Controls network traffic and applies security rules

Frequently asked questions — Lesson 1

Q: I want to stop a service, but the “Stop” button is greyed out. Why?

A: Most likely `services.msc` was opened without administrator rights, or the service depends on another service (dependency). Open the console again as administrator.

Q: How do I find out the service name (for example Spooler)?

A: Double-click the service in `services.msc` — the “Service name” on the General tab is exactly this internal name. Commands (`sc`, `Get-Service`) use this name, not the `DisplayName`.

Q: Which services are safe to disable?

A: Only those you are sure you do not need (for example Print Spooler if there is no printer). Never disable core services such as `RpcSs` or `DcomLaunch` — the system may stop working.

Q: Is the SYSTEM account even more powerful than administrator?

Service name	What it does
--------------	--------------

A: Yes. SYSTEM is the highest local privilege, running in the name of the operating system itself. That is why capturing a service with SYSTEM rights is the most valuable target for an attacker.

Review questions — Lesson 1

1. How does a Windows service differ from an ordinary program?
2. Explain the difference between the SYSTEM, LocalService and NetworkService accounts.
3. What tasks does the Service Control Manager (SCM) perform and where is it located?
4. List the four startup types and explain when each is used.
5. Why can privilege escalation happen through a misconfigured service?
6. What is the difference between the sc query and sc config commands?
7. Why is checking services important in a forensic analysis?

Lesson 2. Windows OS Services (Seminar)

Topic: Windows OS Security **Lesson type:** Seminar **Duration:** 2 hours

Learning questions

1. The User Account Control, AppLocker and SmartScreen security systems
2. The Defender and Firewall security systems

Question 1. The UAC, AppLocker and SmartScreen security systems

1.1. User Account Control (UAC)

In older Windows versions (for example Windows XP), users often worked with administrator rights all the time. This was very dangerous: if such a user accidentally launched malware, that program immediately had full administrator rights as well. UAC (User Account Control) is the mechanism introduced in Windows Vista to solve exactly this problem.

The main idea of UAC is simple: even if you are working under an administrator account, the system makes you do your everyday work with “reduced” (standard) rights. If a program or action requires administrator rights (for example installing a program or changing system settings), a special request — a confirmation window — appears on the screen, and the action is performed only if the user says “Yes”.

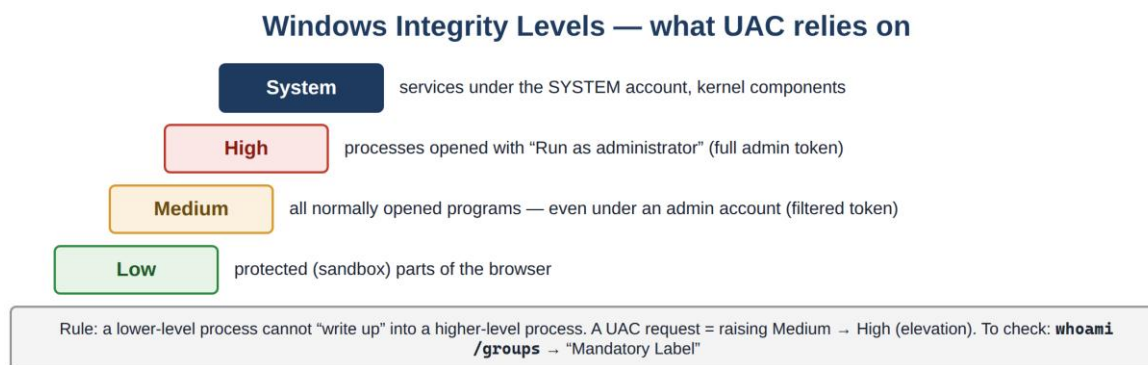


Figure 29. Windows Integrity Levels

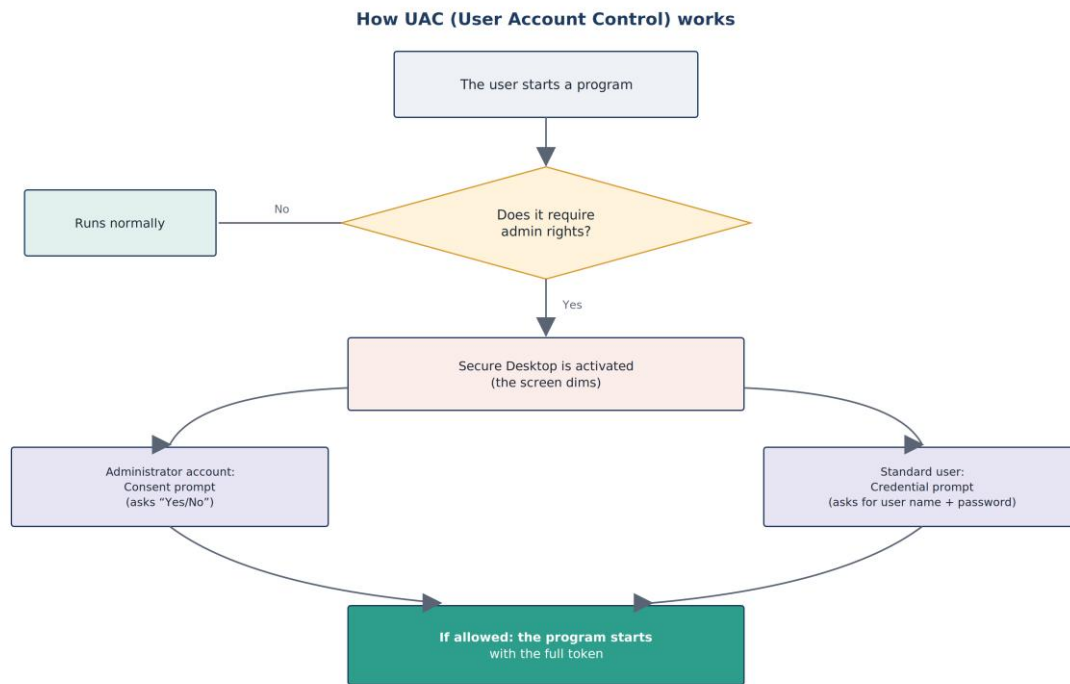


Figure 30. How UAC (User Account Control) works

Note: the confirmation window is shown in a special “Secure Desktop” mode (that is why the screen dims a little) — this security measure prevents malware from automatically clicking a fake “Yes” button. The type of confirmation requested depends on the type of user:

3. **For an administrator — the Consent prompt:** simply clicking “Yes” or “No” is enough.
4. **For a standard user — the Credential prompt:** to continue, an administrator’s user name and password must be entered.

What does the UAC confirmation window look like in practice? Three cases are shown below. The first is a **signed, trusted program** (for example one of Microsoft’s own tools): the “Verified publisher” line is green.

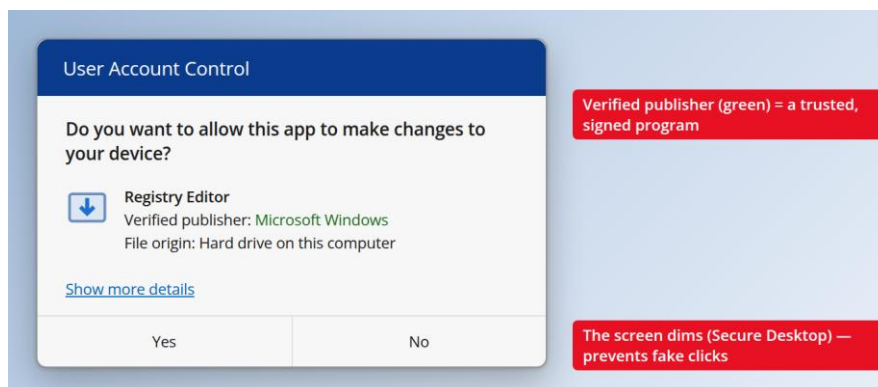


Figure 31. UAC Consent prompt — a signed program (Verified publisher in green)

The second is **an unsigned, unknown program**. “Unknown publisher” is shown in red. This is a serious warning sign: in this situation it is better to click “No”.

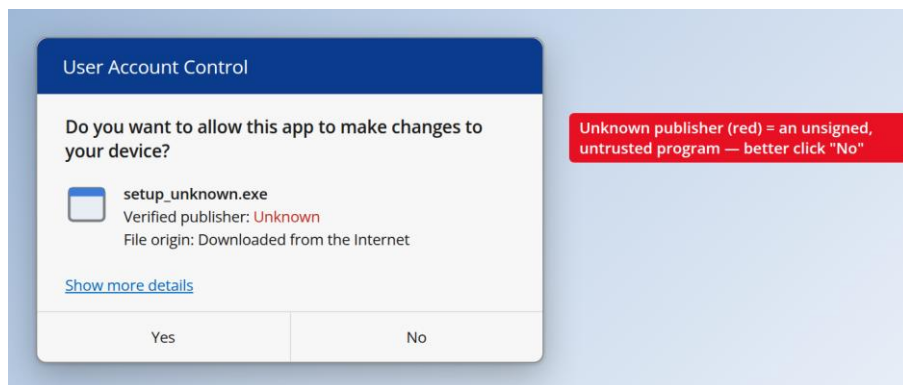


Figure 32. UAC — an unsigned program (Unknown publisher in red)

The third is for **a standard (ordinary) user**. Here, instead of a simple “Yes/No”, a **Credential prompt** appears: to continue, an administrator’s user name and password must be entered.

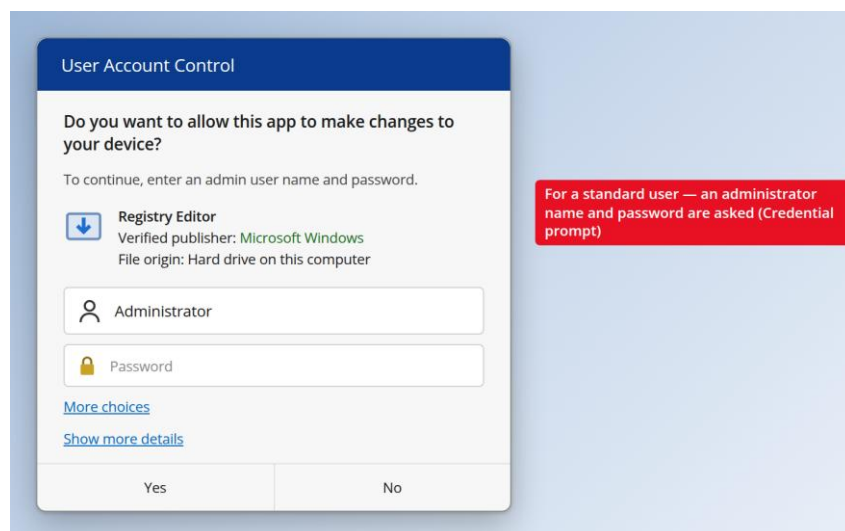


Figure 33. UAC Credential prompt — a standard user is asked for an admin password

How is this done? When you sign in with an administrator account, Windows gives you two “tokens” (sets of rights):

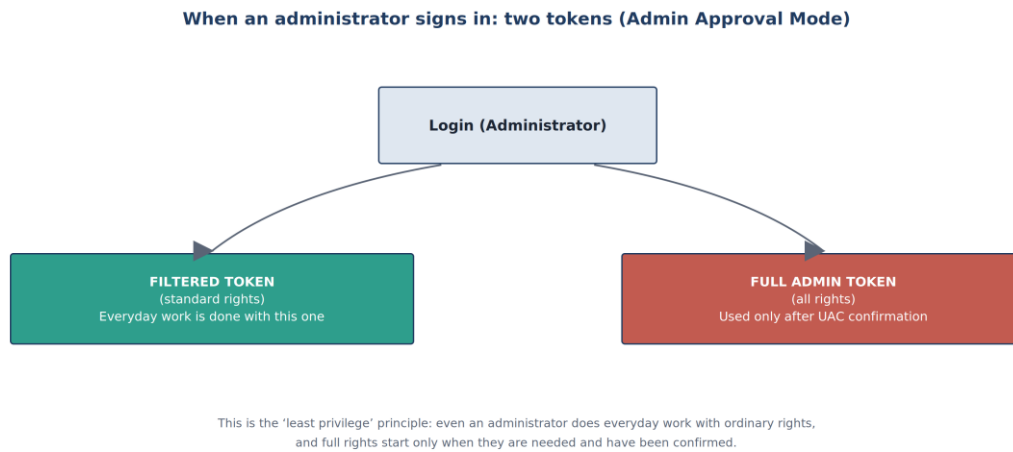


Figure 34. The two tokens created when an administrator signs in (Admin Approval Mode)

This is the practical form of the “least privilege” principle: even an administrator does everyday work with ordinary rights, and full rights are activated only at the moment they are needed and confirmed.

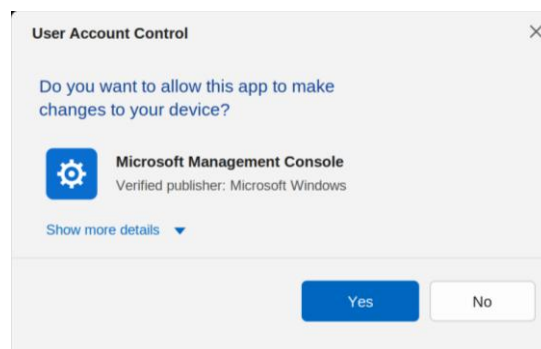


Figure 35. The UAC confirmation window (Consent prompt) — in Secure Desktop mode

In the window above, Windows shows the program’s name, its publisher (**Verified publisher**) and its signature status. If this line says “Unknown publisher” in red, that is a serious warning sign: an unsigned, untrusted program is asking for administrator rights. In that situation it is safer to click “No”.

UAC levels (UAC slider)

Now let us show exactly where the UAC slider is opened. **Win** + **R** → **control** → User Accounts → “Change User Account Control settings” (or search the Start menu directly for “User Account Control”). The window that opens looks like this:

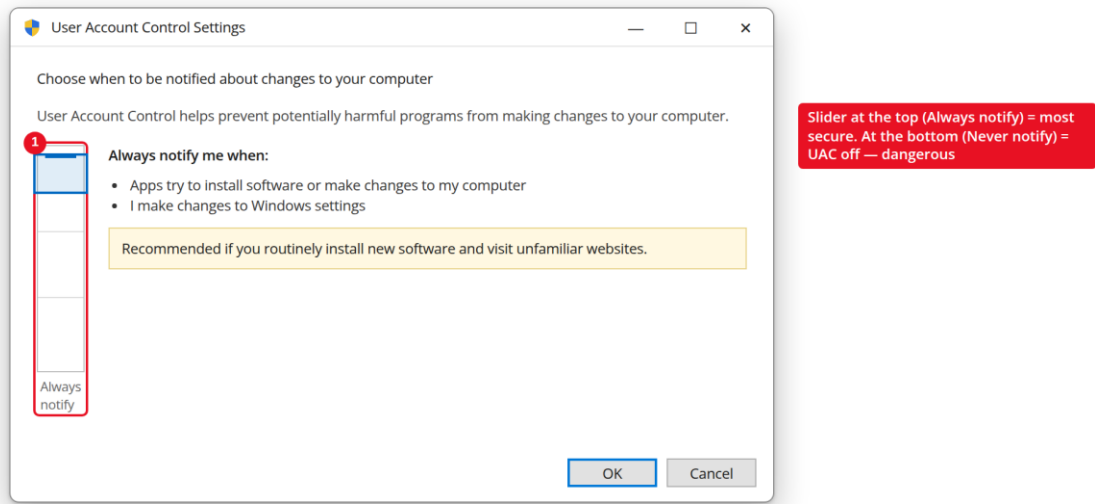


Figure 36. The UAC settings window — slider at the highest level (Always notify)

In Control Panel (Control Panel → User Accounts → Change User Account Control settings) you can set four sensitivity levels for UAC:

Level	Description
Always notify	Highest security: warns about every change (even in Windows settings) and uses the Secure Desktop.
Notify only when apps try to make changes (default)	Warns only when programs try to make changes; does not ask for Windows settings. The level recommended for most users.
Notify only when apps try (do not dim the desktop)	Same as above, but the Secure Desktop is not used — security is somewhat lower.
Never notify	UAC is turned off completely — not recommended, it lowers security significantly.

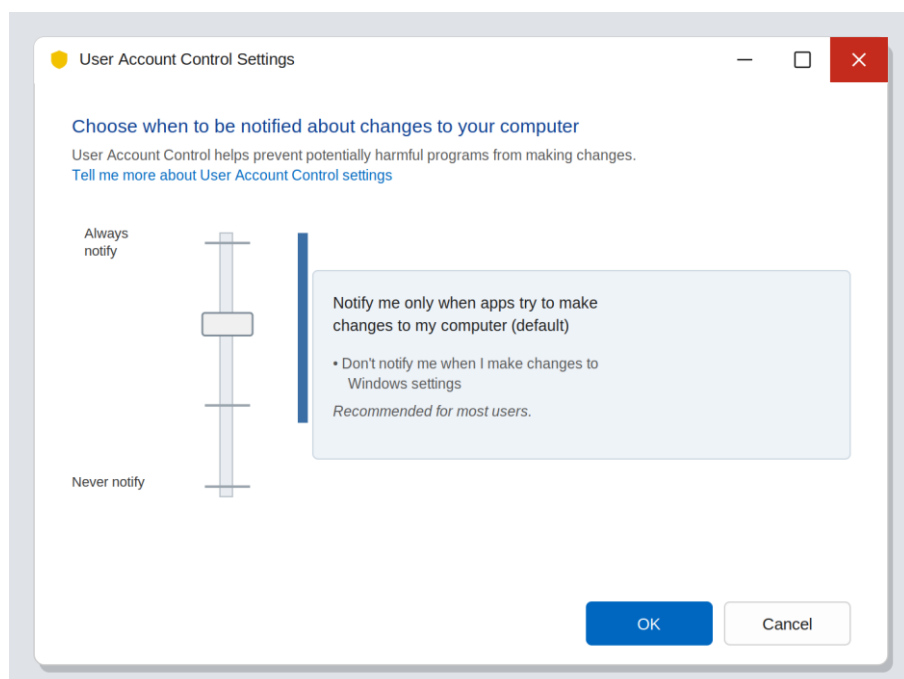


Figure 37. The UAC level settings window (User Account Control Settings)

In practice this slider is the most frequently used setting. By default it sits at the second (default) level. In environments with high security requirements — for example military or government networks — it is recommended to move the slider to the highest level, **Always notify**. The lowest level, **Never notify**, turns UAC off completely and should never be used.

What registry values the UAC slider turns into			
Slider position	ConsentPromptBehaviorAdmin	PromptOnSecureDesktop	Result
Always notify	2	1	On every change, on the dimmed secure desktop
Notify ... (default)	5	1	Only for programs, on the dimmed secure desktop
Notify ... (do not dim)	5	0	Only for programs, the screen is not dimmed
Never notify	0	0	Never asks (EnableLUA is still 1)

Registry path: `HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System`. The slider changes these two values. `EnableLUA = 0` turns UAC off completely (takes effect only after a restart).

Figure 38. UAC slider positions and their registry values

1.2. AppLocker

While UAC controls who can do what, AppLocker controls which programs are allowed to run at all. In other words, AppLocker is an “allowed programs list” (whitelist) mechanism: the administrator defines in advance which programs, scripts or installers may run, and everything else is blocked automatically.

This is especially important in corporate and military organizations: if an employee accidentally or deliberately tries to run malware from an unknown source (for example from a USB flash drive), AppLocker stops it automatically — even if the user says “Yes”.

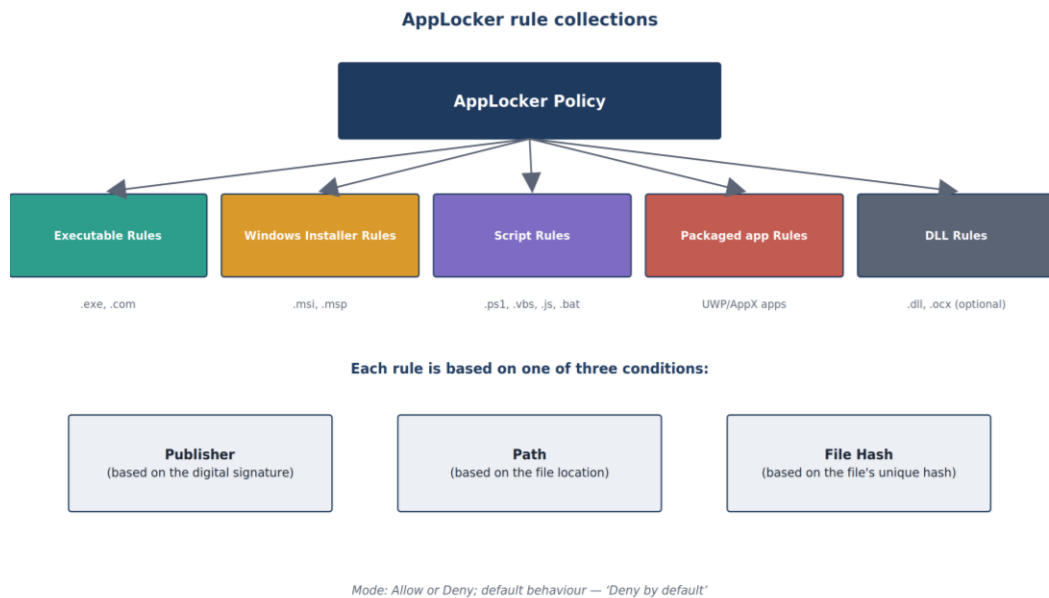


Figure 39. AppLocker rule collections and conditions

AppLocker is divided into five rule collections — Executable (.exe/.com), Windows Installer (.msi/.msp), Script (.ps1/.vbs/.js/.bat), Packaged app (UWP apps) and DLL. Each rule can be based on one of three conditions:

5. **Publisher:** allows a program based on its digital signature (its vendor) — the most flexible method, because the rule keeps working even when the program is updated.
6. **Path:** allows a program based on the location of the file (for example, only programs inside C:\Program Files are allowed).
7. **File Hash:** allows a program based on the unique digital “fingerprint” of that exact file — the strictest method, but the rule must be rewritten whenever the program is updated.

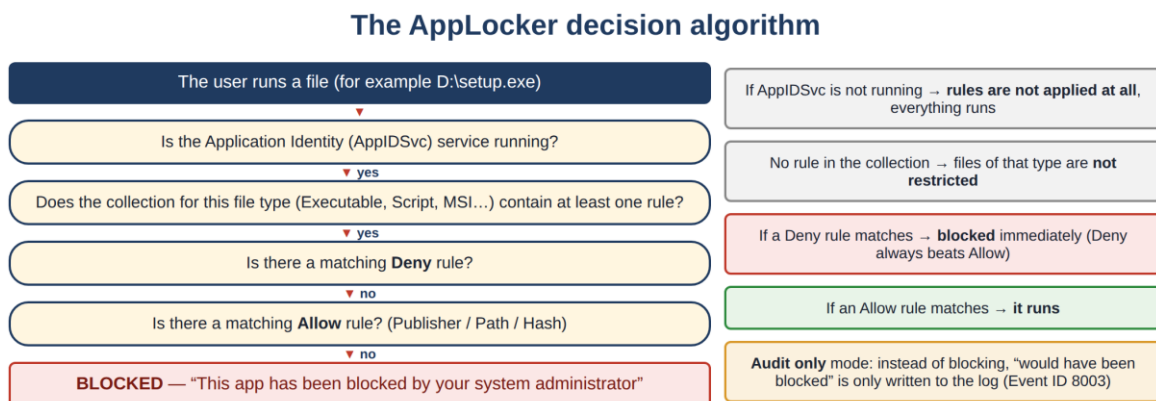


Figure 40. The AppLocker decision algorithm

Important note

- For AppLocker to work, the “Application Identity” (AppIDSvc) service must be running — this ties directly to the service concept learned in Lesson 1.
- AppLocker works fully only in the Windows Enterprise/Education/Server editions; it is limited in the Home and Pro editions.

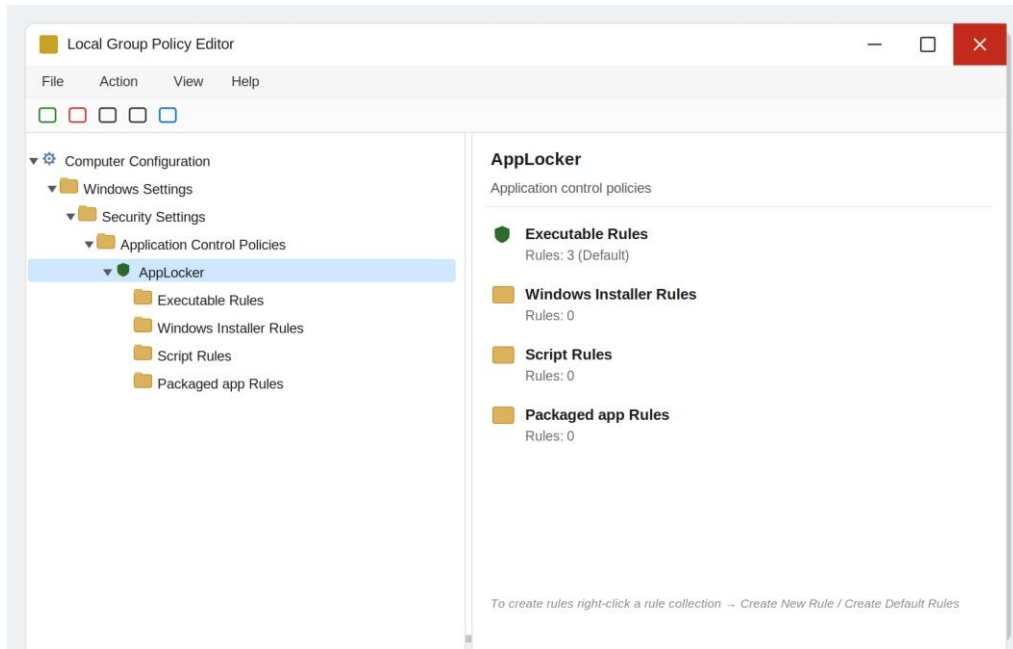
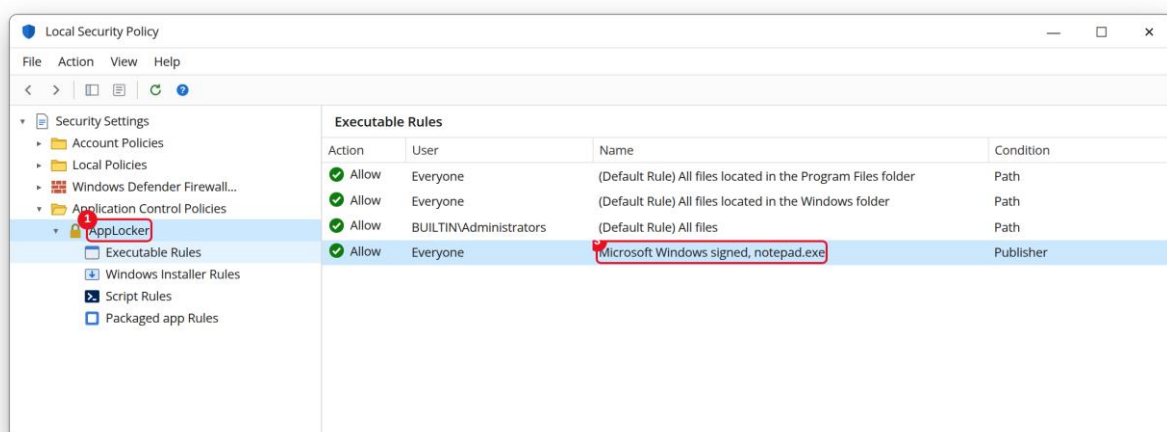


Figure 41. AppLocker rules in the Local Group Policy Editor (gpedit.msc)

Where exactly is AppLocker located? You will find it inside **secpol.msc** (Local Security Policy): **Application Control Policies** → **AppLocker**. (On domain computers it is managed centrally through Group Policy — **gpedit.msc**.)



AppLocker is here: secpol.msc → Application Control Policies

5 rule types: Executable, Installer, Script, Packaged, DLL

Figure 42. AppLocker inside secpol.msc (Application Control Policies)

When you create a new rule (right-click → “Create New Rule”), a wizard opens. At its “Conditions” step, one of the three conditions described above is chosen:

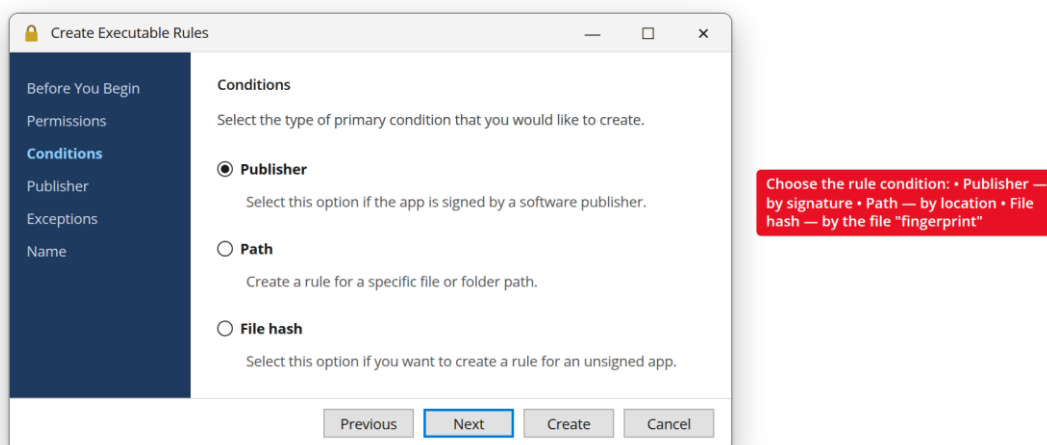


Figure 43. The AppLocker rule creation wizard — the condition selection step

When someone tries to run a program that is not covered by a rule, the following window appears — the program is blocked, even if the user is an administrator:

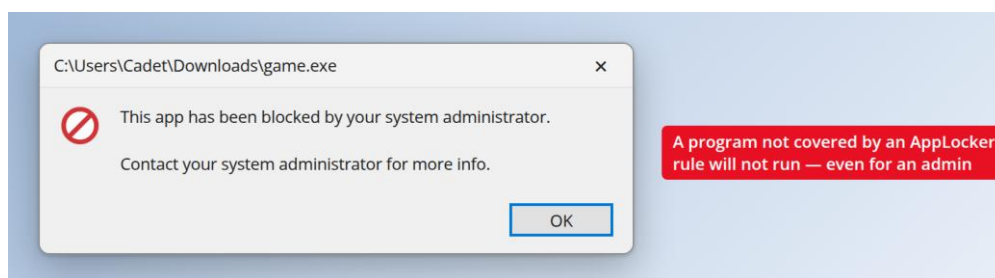


Figure 44. The window of a program blocked by AppLocker

Practical example: if the organization creates a Path rule that allows programs to run only from the C:\Program Files and C:\Windows folders, any .exe file the user tries to run from the Downloads folder or a USB flash drive is blocked automatically — even if the user is an administrator.

1.3. Windows SmartScreen

While AppLocker controls programs on the local system, SmartScreen checks how dangerous files downloaded from the internet and the websites being visited are. SmartScreen uses Microsoft’s large cloud database, which holds information about the “reputation” of millions of files and sites.

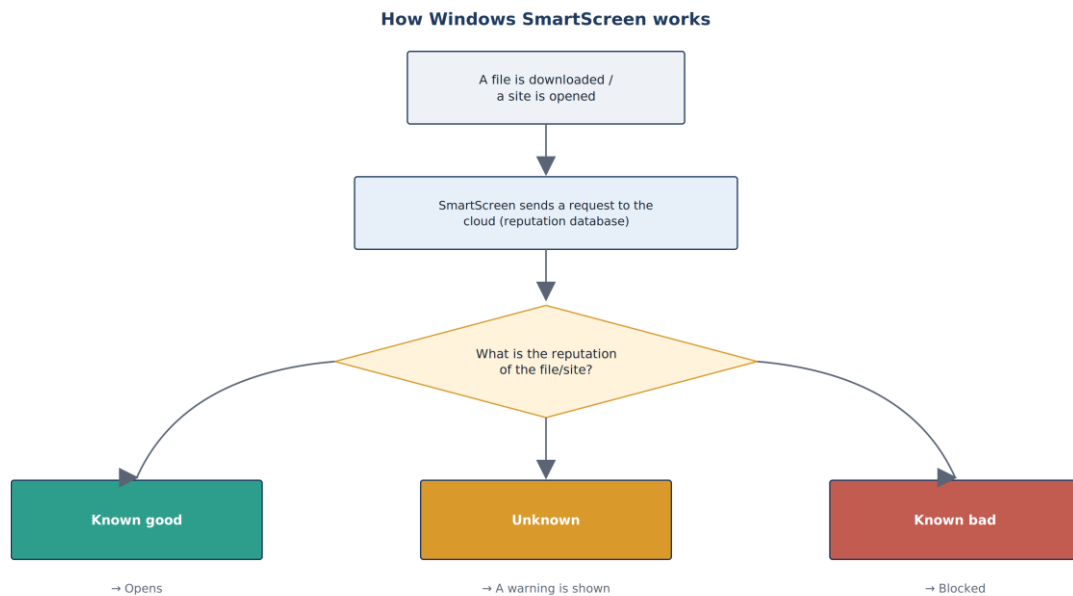


Figure 45. How Windows SmartScreen works

If a file or site is new (nobody has opened it yet) or has a low reputation, SmartScreen shows a warning such as “Unknown publisher” or “Do you want to continue the download?”. This is very effective protection against phishing (fraud) sites and newly spreading malware, because it can catch threats for which no traditional antivirus signature exists yet.

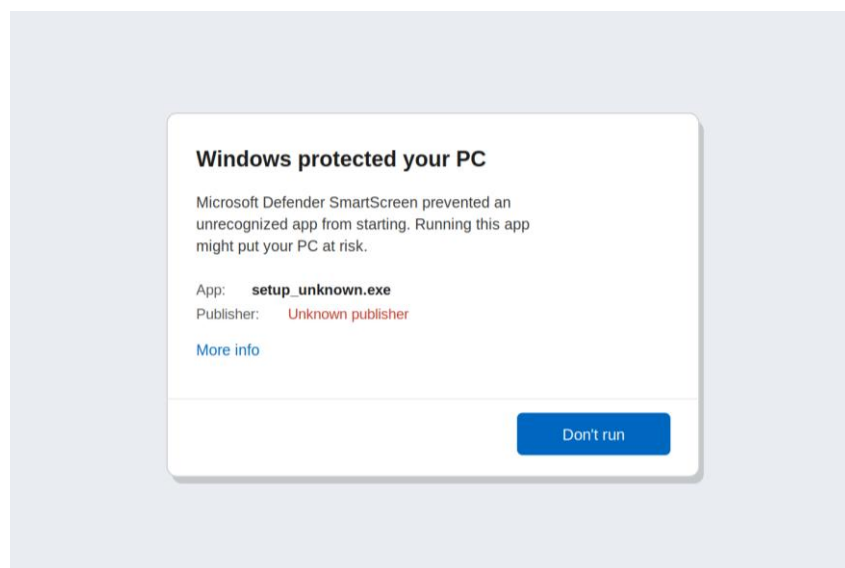


Figure 46. The Windows SmartScreen warning window

This is what a SmartScreen warning looks like in practice. Clicking “More info” reveals the program name and publisher; “Run anyway” lets you continue while taking responsibility yourself:

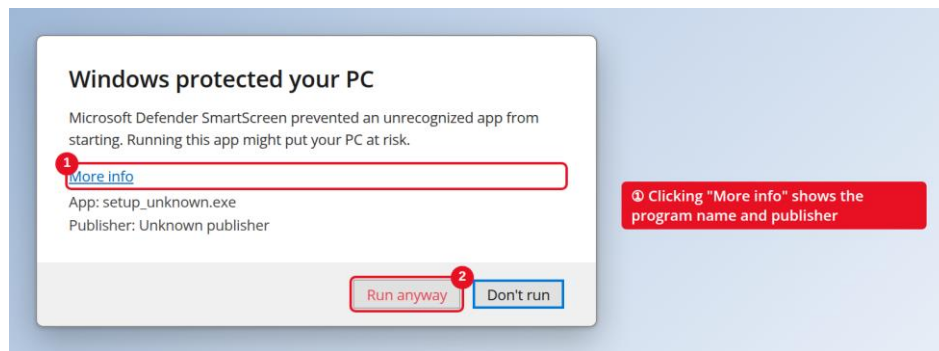


Figure 47. SmartScreen — the “Windows protected your PC” window (annotated)

Where are the SmartScreen settings? **Windows Security** → **App & browser control** → “**Reputation-based protection settings**”. Here it can be turned on or off (it is recommended to keep it always on):

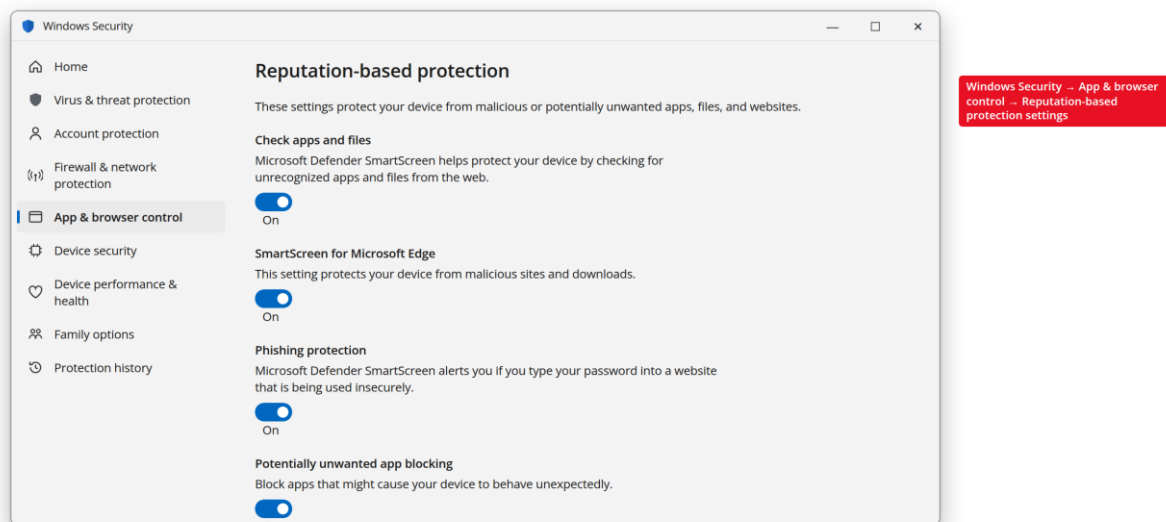


Figure 48. SmartScreen settings (Reputation-based protection)

For example, when you try to run an unsigned file `setup_unknown.exe` downloaded from the internet, SmartScreen shows the window above and blocks the file. The user can continue only through the “More info → Run anyway” link, taking responsibility on themselves — and this makes the user stop for a moment and think.

How SmartScreen “recognizes” a file: Mark of the Web (Zone.Identifier)



Figure 49. SmartScreen and the Mark of the Web (Zone.Identifier)

Question 2. The Defender and Firewall security systems

2.1. Windows Defender (Microsoft Defender Antivirus)

Windows Defender is the antivirus and antimalware solution created by Microsoft that comes built into Windows. While UAC, AppLocker and SmartScreen focus on “blocking in advance”, Defender focuses on actively scanning files that already exist or are running on the system and detecting malicious behavior.

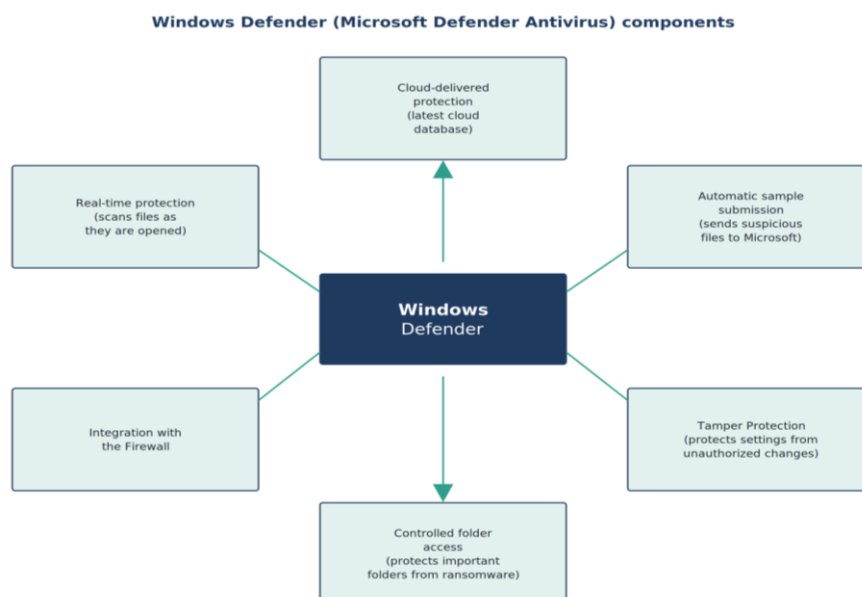


Figure 50. Windows Defender components

Component	What it does
Real-time protection	Checks every file immediately as it is opened, downloaded or run.
Cloud-delivered protection	Detects new threats that are not in the local database, using the latest database in the cloud.
Automatic sample submission	Automatically sends a sample of a suspicious but still unknown file to Microsoft for analysis.
Tamper Protection	Protects Defender’s settings from being changed or turned off by malware or an intruder.
Controlled folder access	Protects important folders (Documents, Pictures) from unauthorized changes (for example ransomware encryption).

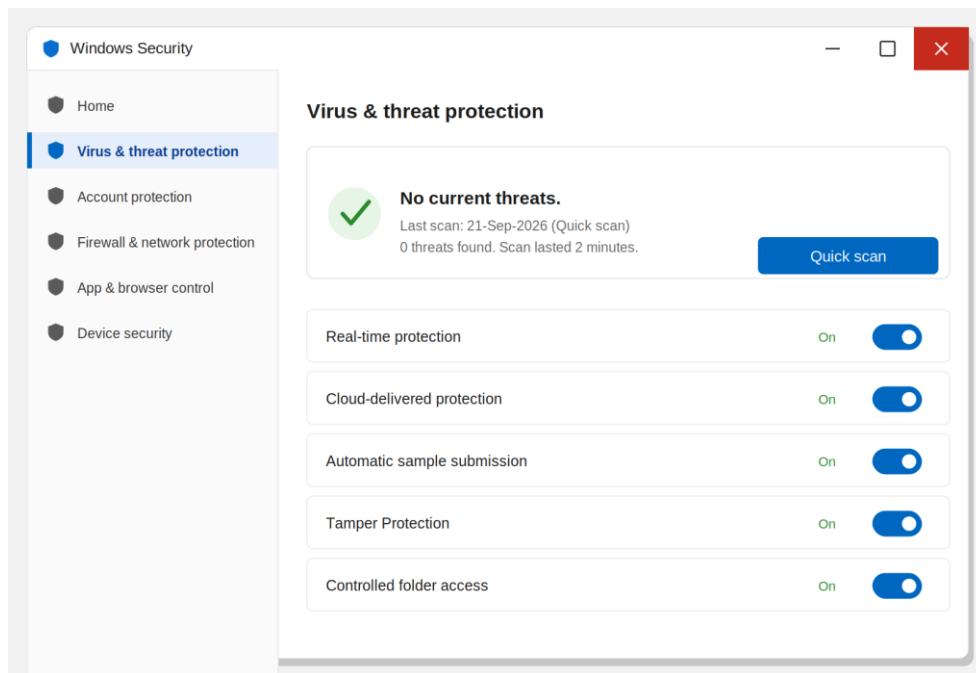


Figure 51. Windows Security — the “Virus & threat protection” section (Microsoft Defender)

2.2. Windows Firewall

Windows Firewall is the wall that controls traffic between the computer and the outside network (the internet or the local network). It checks traffic in two directions: Inbound (coming into the computer) and Outbound (leaving the computer). Each rule defines whether traffic for a particular port, program or protocol is allowed or blocked.

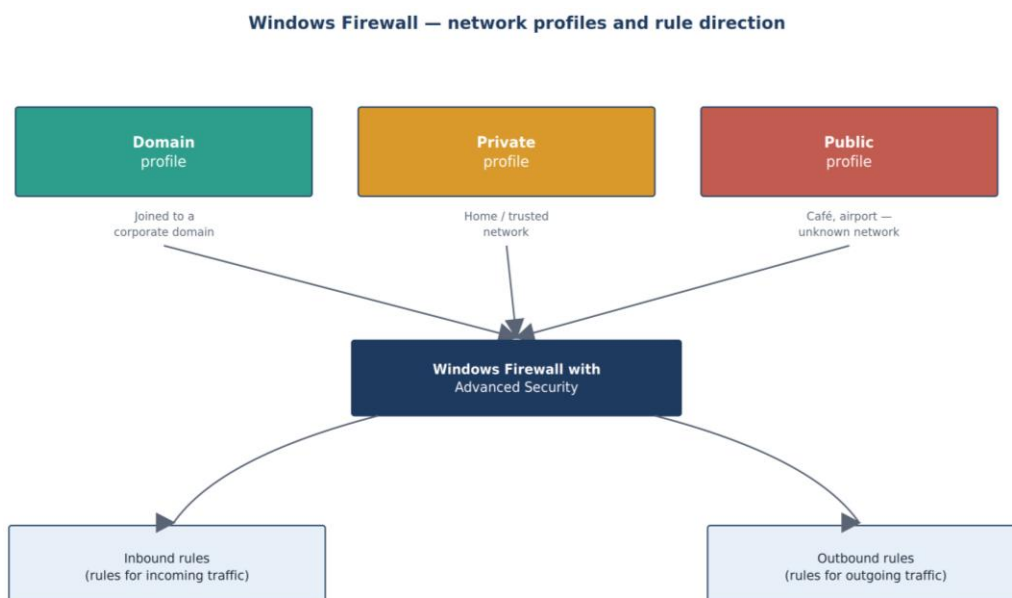


Figure 52. Windows Firewall network profiles and rule direction

An important feature of the firewall is that it applies a different profile depending on what type of network you are connected to, because the risk on a home network differs from open Wi-Fi in a café:

Profile	When it is applied	Typical security level
Domain	When the computer is joined to a corporate domain (Active Directory)	Medium — higher trust in the internal network
Private	When connected to a home or trusted private network	Medium
Public	On unfamiliar networks such as cafés, airports and hotels	Strictest — most incoming connections are blocked

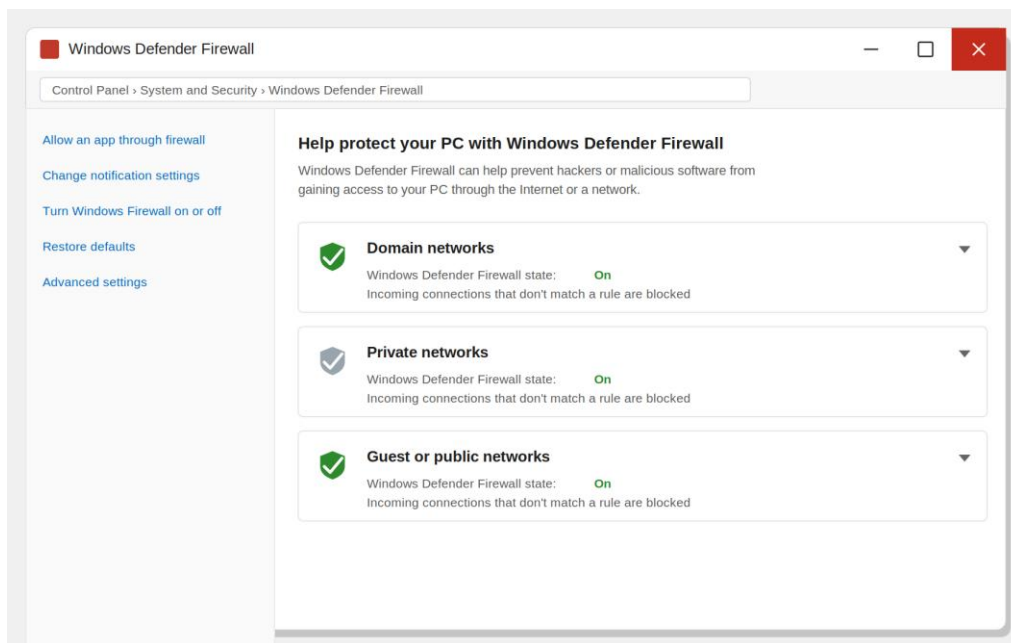


Figure 53. Windows Defender Firewall — network profiles (Control Panel)

Where is Windows Firewall opened? The simplest way is **control** → Windows Defender Firewall. This window shows the three profiles (Domain, Private, Public) and their status:

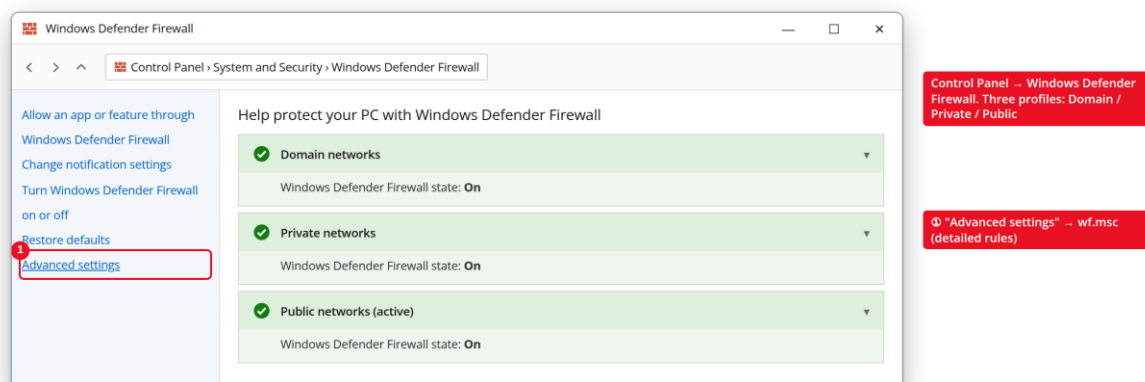
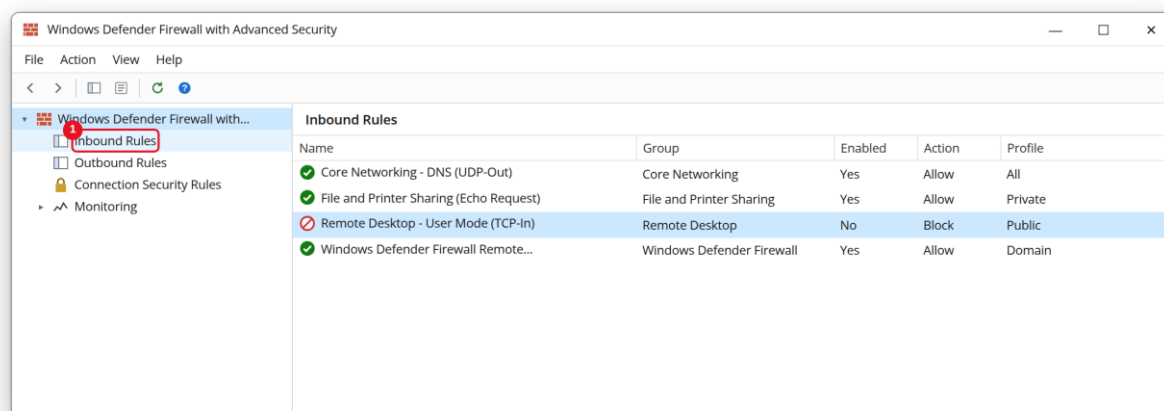


Figure 54. Windows Defender Firewall (Control Panel) — status of the three profiles

For detailed rules (allowing/blocking a specific port or program), **wf.msc** is opened through the “**Advanced settings**” link on the left. Here there are lists of **Inbound** and **Outbound** rules:



wf.msc — the advanced firewall. Inbound (incoming) and Outbound (outgoing) rules: Allow/Block

Figure 55. wf.msc — the advanced firewall, Inbound rules (Allow/Block)

A separate set of rules is kept for each profile. For example, when you connect to open Wi-Fi in a café, Windows applies the **Public** profile and blocks almost all incoming connections; on your trusted home network, the **Private** profile allows services such as file sharing.

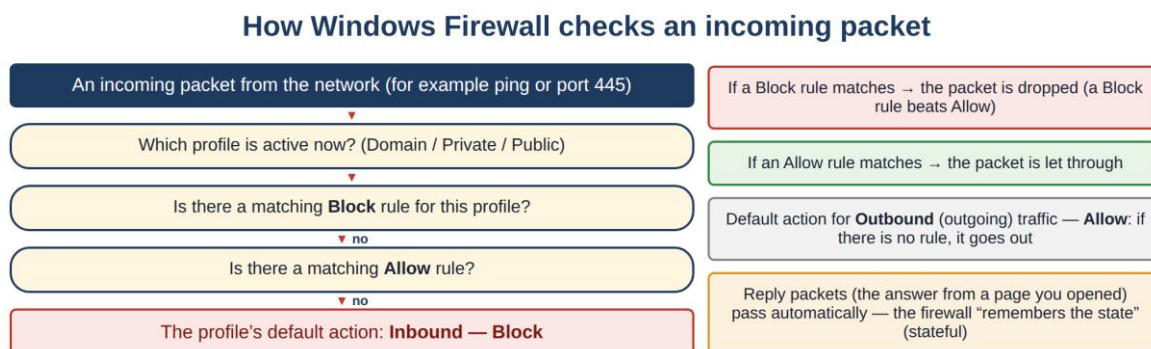


Figure 56. The Windows Firewall algorithm for checking an incoming packet

Additional important information — how all the tools work together

UAC, AppLocker, SmartScreen, Defender and Firewall are layers that work separately but together form the “defense in depth” principle. The essence of this principle: even if an attacker manages to bypass one layer, the next layer stops them.

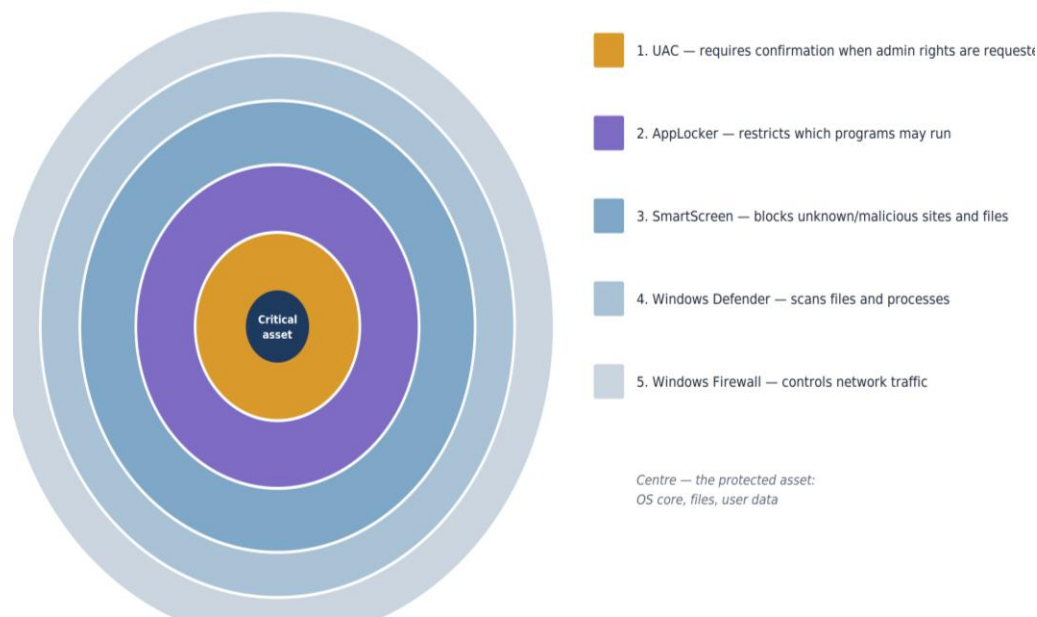


Figure 57. Windows OS: layers of defense in depth

Tool	What it mainly protects against
UAC	Admin rights being used without the user's knowledge
AppLocker	Unauthorized/unknown programs running
SmartScreen	Malicious files downloaded from the internet and phishing sites
Windows Defender	Malicious code (viruses, trojans, ransomware) already present or running on the computer
Windows Firewall	Unauthorized connections coming in or going out over the network

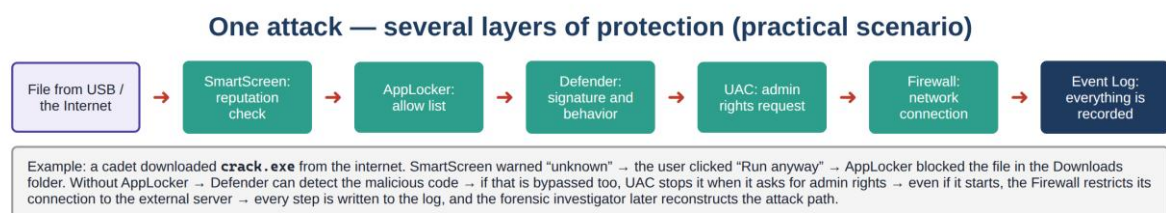


Figure 58. Several layers of protection against a single attack (scenario)

Frequently asked questions — Lesson 2

Q: I cannot find AppLocker — it is not in secpol.msc?

A: Your Windows edition may be Home. AppLocker works fully only in the Enterprise/Education and Server editions. Check your edition with **winver**.

Q: What is the difference between UAC and AppLocker? Don't both of them stop programs?

A: UAC asks for **confirmation** before a program gets admin rights (if the user says “Yes”, it goes through). AppLocker, on the other hand, forbids the program from **running at all** (saying “Yes” does not help).

Q: Are SmartScreen and Defender the same thing?

A: No. SmartScreen checks **new/unknown** files and sites coming from the internet by their reputation (before they run). Defender is the antivirus that scans files **already present** on the system.

Q: How can I tell the difference between the Public and Private profiles?

A: When you connect to a new network, Windows asks “is this network private?”. If you say “No”, the Public (stricter) profile is applied; if you say “Yes”, the Private profile is applied.

Review questions — Lesson 2

1. Why was UAC introduced and what problem does it solve?
2. What is the difference between the Consent prompt and the Credential prompt?
3. Why are the filtered token and the full admin token needed?
4. Explain AppLocker’s three rule conditions (Publisher, Path, File Hash).
5. Against which types of threats is SmartScreen especially effective?
6. What does Windows Defender’s Controlled folder access component protect against?
7. Explain the difference between the Domain, Private and Public firewall profiles.
8. What does the “defense in depth” principle mean?

Lesson 3. Windows OS Services (Practical)

Topic: Windows OS Security **Lesson type:** Practical **Duration:** 4 hours

Learning questions

1. User Account Control
2. The AppLocker and SmartScreen security systems

Attention: This is a practical lesson dedicated to configuring, by hand, in a real (or virtual) Windows environment, the theory learned in Lesson 2. Every action must be done in a dedicated training lab or in a Windows virtual machine in VirtualBox/VMware — never try it on a work or personal computer.

Question 1. Configuring User Account Control (UAC) in practice

Practical task 1.1: Changing the UAC level

1. In the Start menu search box, type “User Account Control” and open “Change User Account Control settings”.

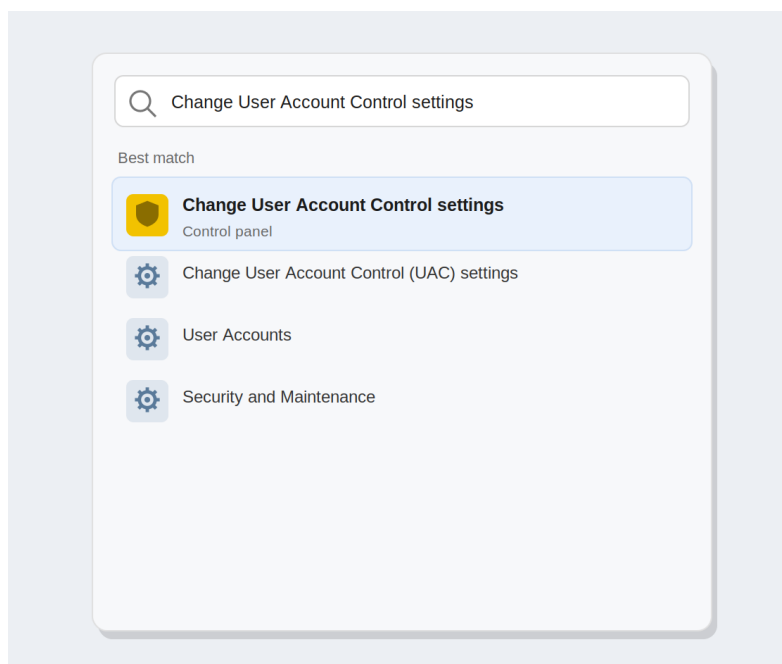


Figure 59. Searching for the UAC setting in the Start menu

2. The window that opens shows a slider — it indicates the four levels.
3. Move the slider to “Always notify” (the highest level) and click “OK”.

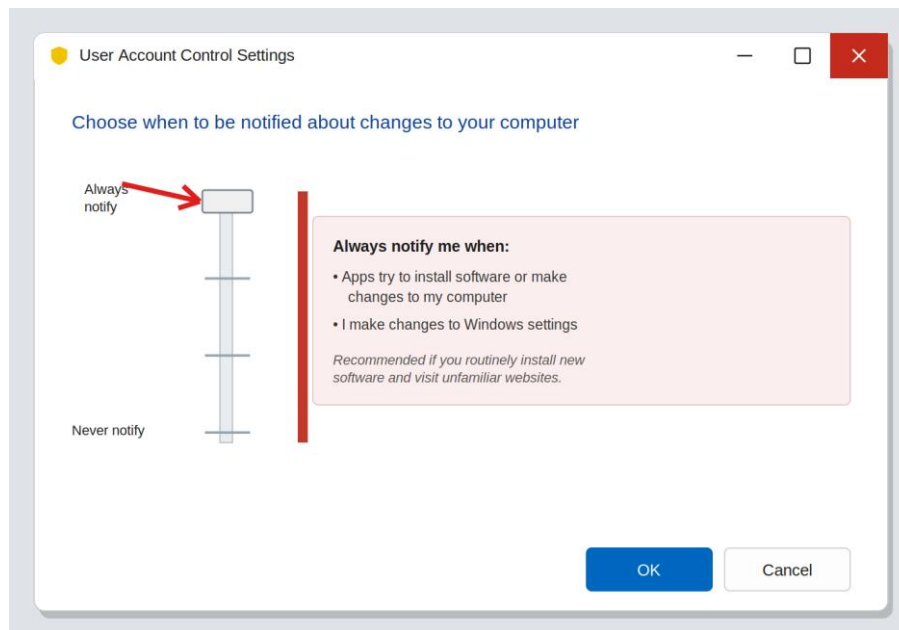


Figure 60. The UAC slider at the highest level, “Always notify”

4. UAC itself asks for confirmation — answer “Yes”.
5. Now try changing any system setting (for example, changing the date) — observe that now even Windows itself asks for confirmation.
6. Return the slider to the default level (“Notify only when apps try to make changes”).

Practical task 1.2: Checking UAC from the command line

Open PowerShell with administrator rights and check the current UAC state with the following command:

Command	Result
Get-ItemProperty HKLM:\Software\Microsoft\Windows\CurrentVersion\Policies\System -Name EnableLUA	Shows whether UAC is enabled (1) or disabled (0)
Get-ItemProperty HKLM:\Software\Microsoft\Windows\CurrentVersion\Policies\System -Name ConsentPromptBehaviorAdmin	Shows the current UAC prompt behavior for administrators as a number (0–5)

```
Windows PowerShell (Administrator)

Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

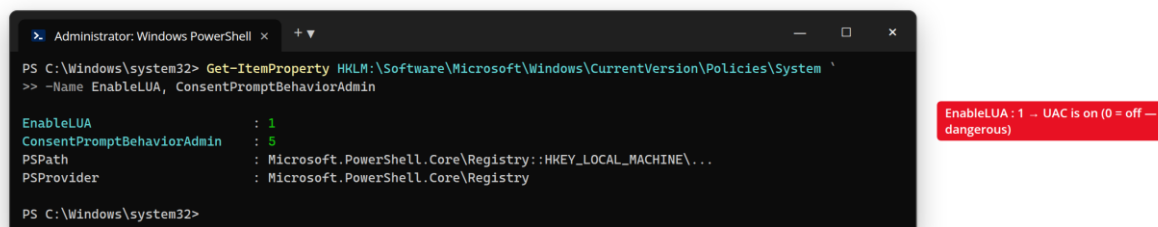
PS C:\WINDOWS\system32> Get-ItemProperty HKLM:\Software\Microsoft\Windows\
CurrentVersion\Policies\System -Name EnableLUA

EnableLUA : 1
PSPath : Microsoft.PowerShell.Core\Registry::HKEY_LOCAL_MACHINE\...
PSProvider : Microsoft.PowerShell.Core\Registry

PS C:\WINDOWS\system32> _
```

Figure 61. PowerShell — result of checking the UAC state (EnableLUA)

The full output of the command and its meaning are shown below. **EnableLUA** indicates whether UAC is enabled, and **ConsentPromptBehaviorAdmin** indicates the prompt type for administrators:



```
PS C:\Windows\system32> Get-ItemProperty HKLM:\Software\Microsoft\Windows\CurrentVersion\Policies\System `
>> -Name EnableLUA, ConsentPromptBehaviorAdmin

EnableLUA           : 1
ConsentPromptBehaviorAdmin : 5
PSPPath             : Microsoft.PowerShell.Core\Registry::HKEY_LOCAL_MACHINE\...
PSProvider          : Microsoft.PowerShell.Core\Registry

PS C:\Windows\system32>
```

EnableLUA: 1 → UAC is on (0 = off — dangerous)

Figure 62. PowerShell — the EnableLUA and ConsentPromptBehaviorAdmin values

In the output, the value **EnableLUA : 1** means UAC is enabled. If this value is 0, UAC is disabled — a serious security weakness that must be fixed immediately. The **ConsentPromptBehaviorAdmin** value sets the prompt type for administrators: 2 — always asks “Yes/No” on the Secure Desktop, 0 — asks nothing (dangerous), 5 — asks only for programs (default).

Note: these registry keys can be changed by hand, but changing them through the GUI is recommended, because a wrong value can make the system unstable.

Question 2. Configuring AppLocker and SmartScreen in practice

Practical task 2.1: Enabling AppLocker and creating a rule

1. First, check that the required service is running: open services.msc, find the “Application Identity” service, set it to “Automatic” and start it (the knowledge from Lesson 1 is applied in practice here).

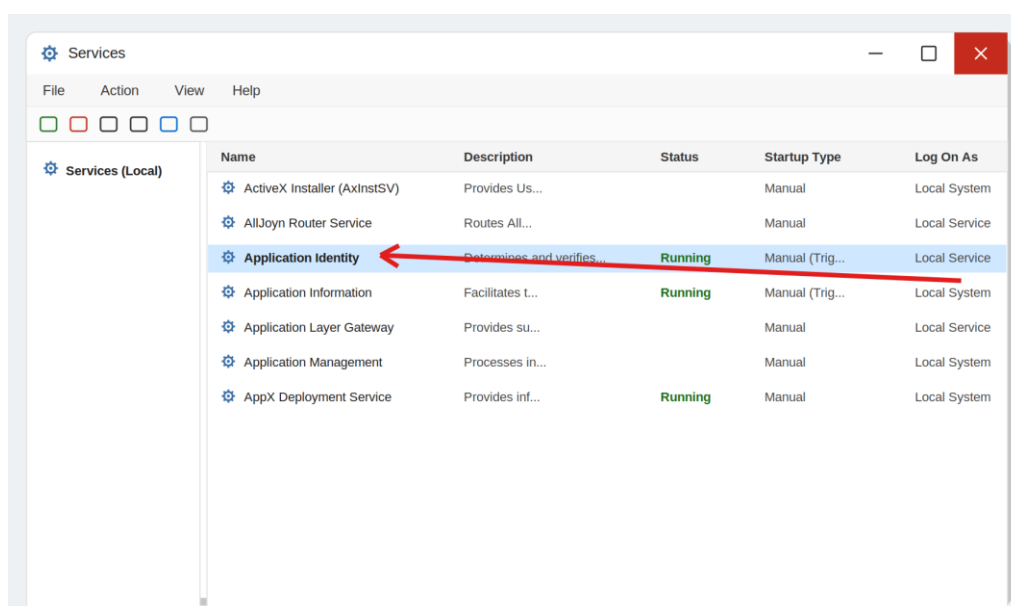


Figure 63. *services.msc* — the “Application Identity” (*AppIDSvc*) service

2. **Win** + **R** → open the Local Group Policy Editor with the `gpedit.msc` command (available only in the Pro/Enterprise editions).
3. Go through the following path: Computer Configuration → Windows Settings → Security Settings → Application Control Policies → AppLocker.
4. Right-click “Executable Rules” and choose “Create Default Rules” — this automatically creates the default rules the system needs.

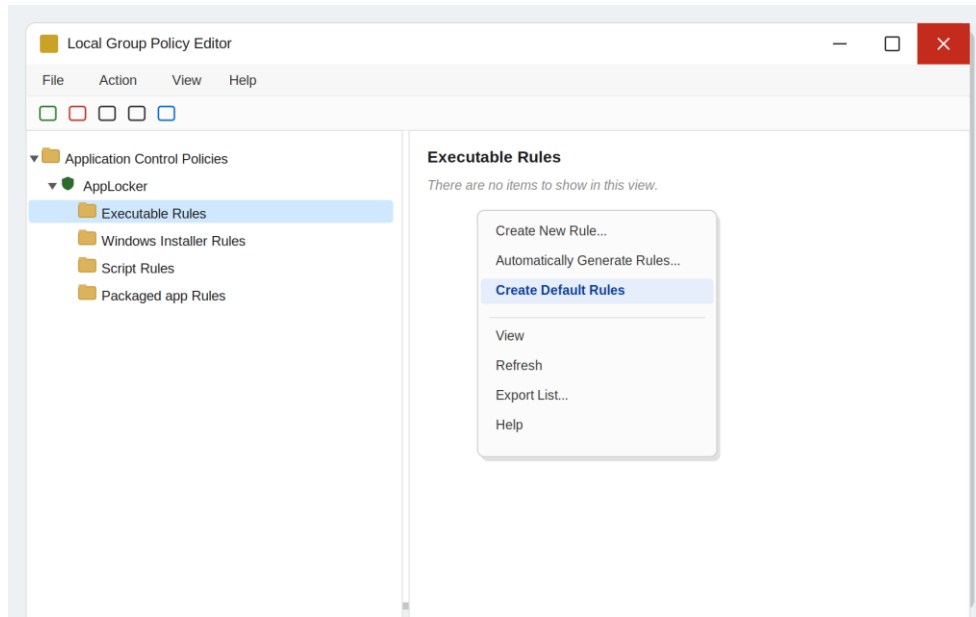


Figure 64. *gpedit.msc* — the “Create Default Rules” command (context menu)

5. To add a new rule, right-click again → “Create New Rule” — answer the prompts, choose the “Publisher” condition and point to a signed program file (for example `notepad.exe`).

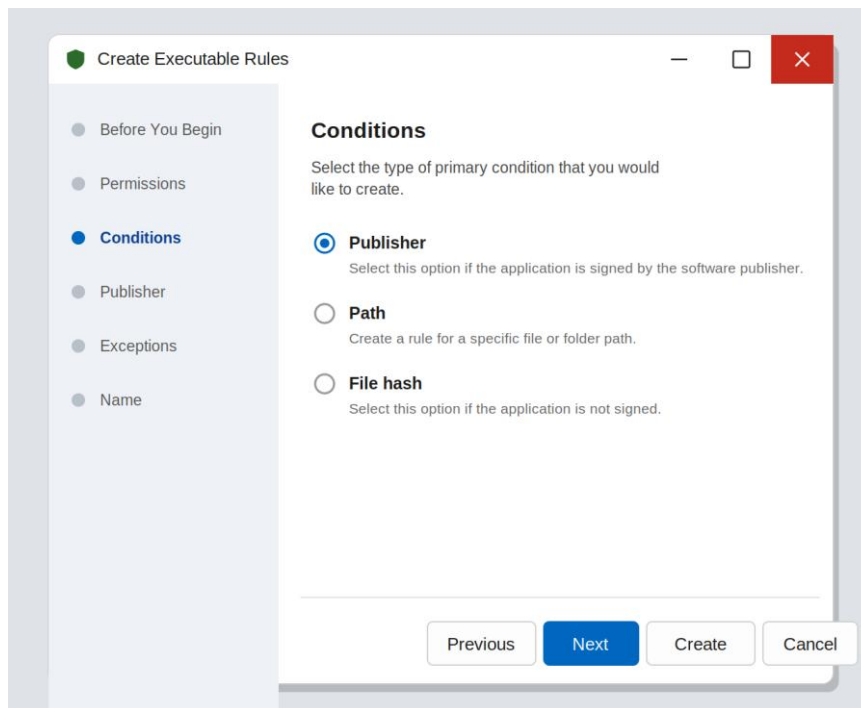


Figure 65. AppLocker — the new rule wizard (Publisher condition)

6. Save the rule in “Allow” mode.
7. To apply the AppLocker settings, run the `gpupdate /force` command in PowerShell.

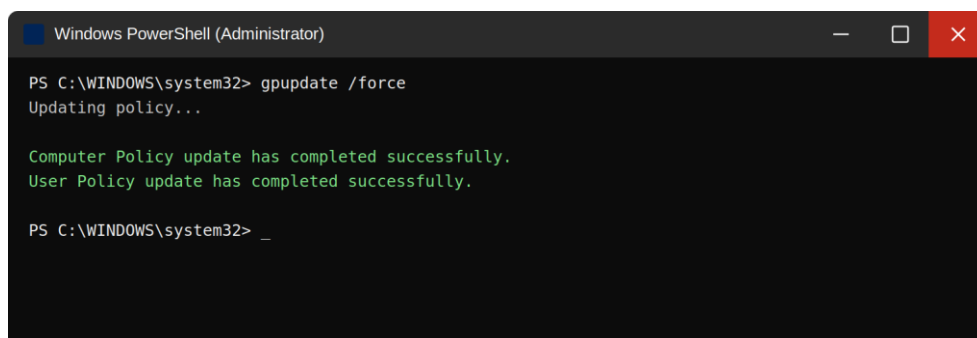


Figure 66. PowerShell — applying the policy with “`gpupdate /force`”

After creating the AppLocker rule, the `gpupdate /force` command is used to apply it immediately. A successful result looks like this:

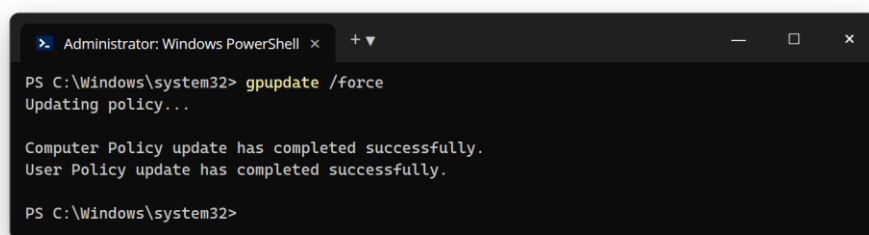


Figure 67. PowerShell — applying the policy with `gpupdate /force`

- Now try to run a program that is not covered by the rule — it should be blocked.

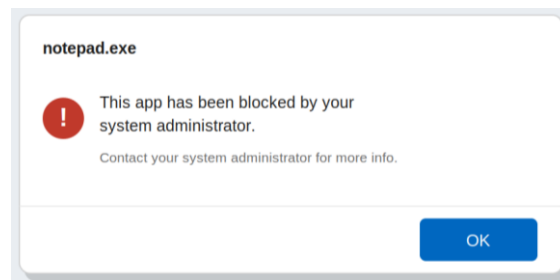


Figure 68. The window of a program blocked by AppLocker

Common mistakes

- AppLocker rules do not work — the cause is usually that the “Application Identity” service has not been started.
- With “Audit only” mode enabled, rules block nothing — this mode is intended only for monitoring; for real blocking, “Enforce Rules” must be selected.
- If the default rules (Create Default Rules) are not created, the system itself may stop working — always create the default rules first.

Practical task 2.2: Checking and configuring SmartScreen settings

- Open the “Windows Security” app → go to the “App & browser control” section.
- Click the “Reputation-based protection settings” link.

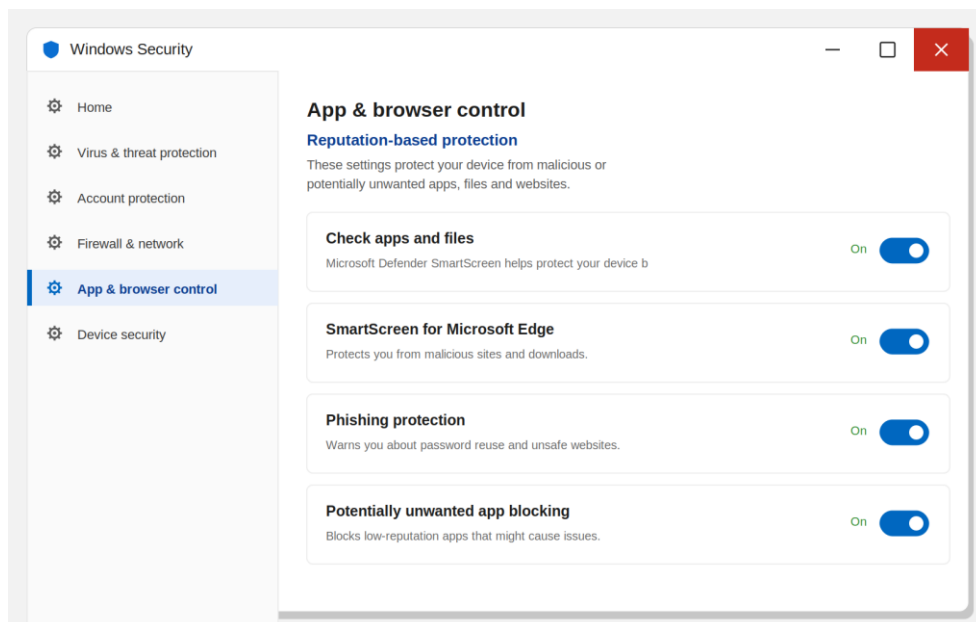


Figure 69. “App & browser control” — Reputation-based protection settings

3. You will see three main settings: “Check apps and files”, “SmartScreen for Microsoft Edge” and “Phishing protection” — leave all of them “On”.
4. With “Check apps and files” turned on, try downloading a file of unknown origin from the internet (for example from an untrusted test site) — observe that SmartScreen shows a warning window.
5. Click the “More info” link in the warning window and study what additional information (publisher, reputation level) it shows.

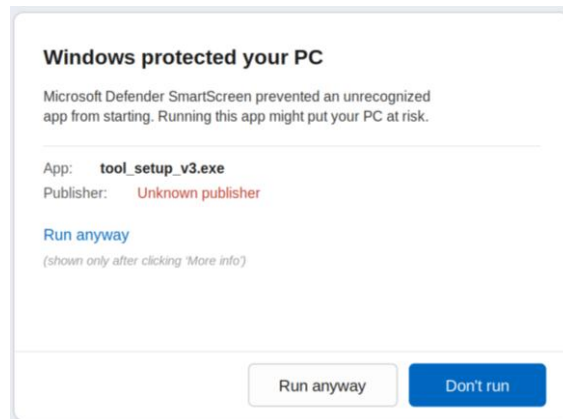


Figure 70. SmartScreen warning and “More info → Run anyway”

Practical lab assignment (final)

Complete the following assignment independently in a virtual machine and present the result in a report (with screenshots):

6. Set the UAC level to “Always notify” and take a screenshot confirming it.
7. Using AppLocker, create a Path rule that allows programs to run only from the C:\Windows and C:\Program Files folders.
8. Try to run any .exe file located outside this rule and confirm with a screenshot that it was blocked.
9. Using SmartScreen, download a file from an unknown source and take a screenshot of the warning window.

Frequently asked questions — Lesson 3

Q: I created an AppLocker rule, but the program still runs. Why?

A: One of three reasons: (1) the **Application Identity** (AppIDSvc) service is not running; (2) the mode is “Audit only” — switch it to “Enforce Rules”; (3) **gpupdate /force** was not run.

Q: I get an error saying secpol.msc or gpedit.msc was not found.

A: These tools do not exist in the Home edition. You need the Pro/Enterprise edition. Install the lab VM accordingly.

Q: Can I turn UAC off completely — its constant prompts annoy me?

A: No, that is not recommended. “Never notify” turns UAC off and lowers security significantly. At most leave it at the default level; in military/government environments “Always notify” is recommended.

Review questions — Lesson 3

1. Which service must be running for AppLocker to work?
2. What is the difference between the “Audit only” and “Enforce Rules” modes?
3. Which command-line tool can be used to check the UAC level?
4. What additional information can the user see when a SmartScreen warning appears?
5. Why is it not recommended to add a custom rule without first creating the default AppLocker rules (Default Rules)?

Lesson 4. Windows OS Services (Practical)

Topic: Windows OS Security **Lesson type:** Practical **Duration:** 4 hours

Learning questions

1. Configuring security settings
2. Configuring user security

Question 1. Configuring security settings (Local Security Policy)

All of Windows' important security settings (password requirements, audit rules, user rights) are gathered in one central place — the Local Security Policy (secpol.msc) tool. This tool is available in the Windows Pro/Enterprise editions, and on domain computers it can also be managed centrally through Group Policy (gpedit.msc / Active Directory GPO).

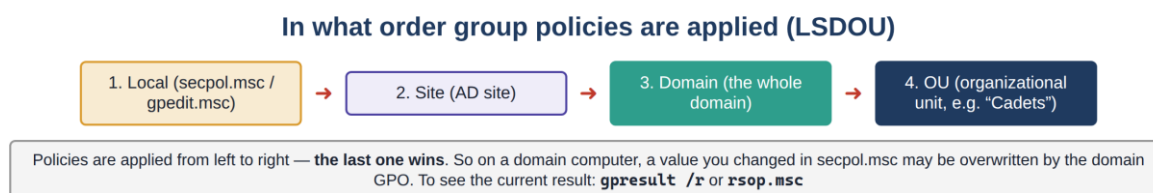


Figure 71. The order in which group policies are applied (LSDOU)

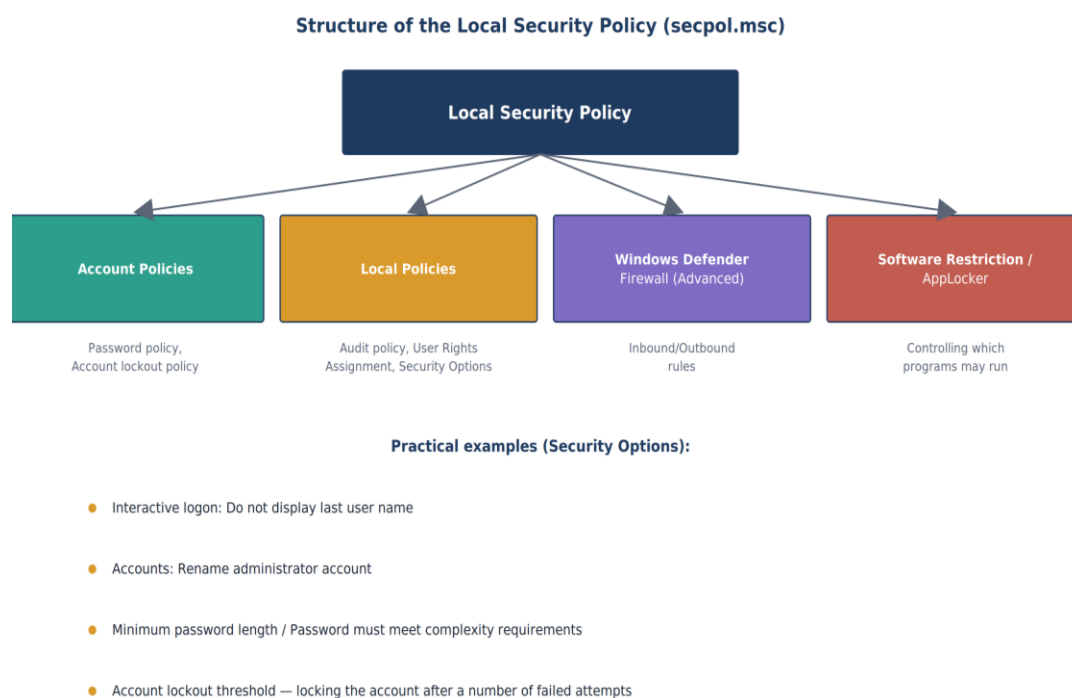


Figure 72. Structure of the Local Security Policy (secpol.msc)

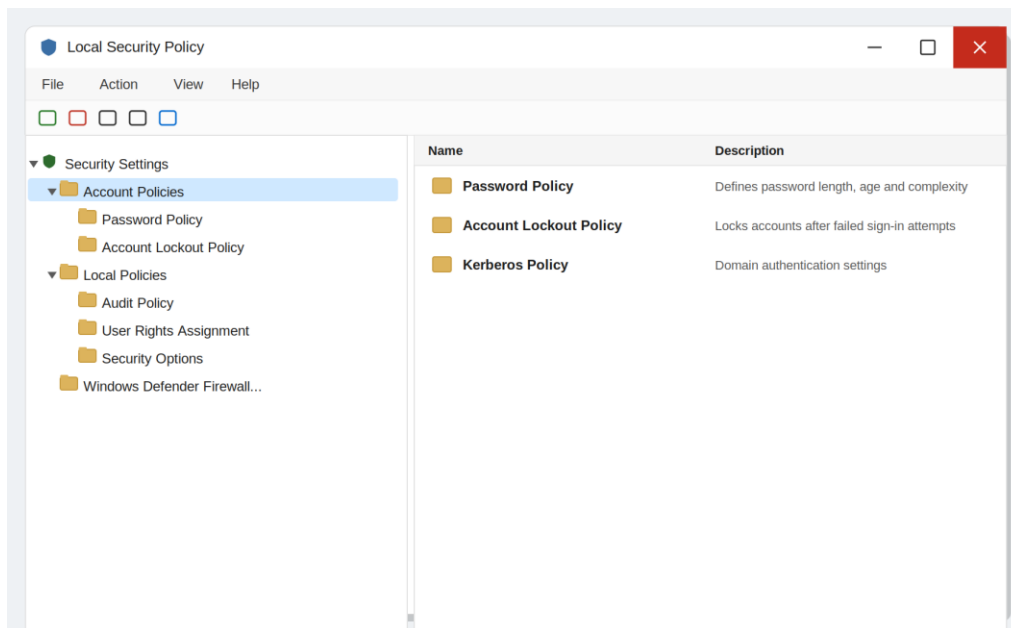
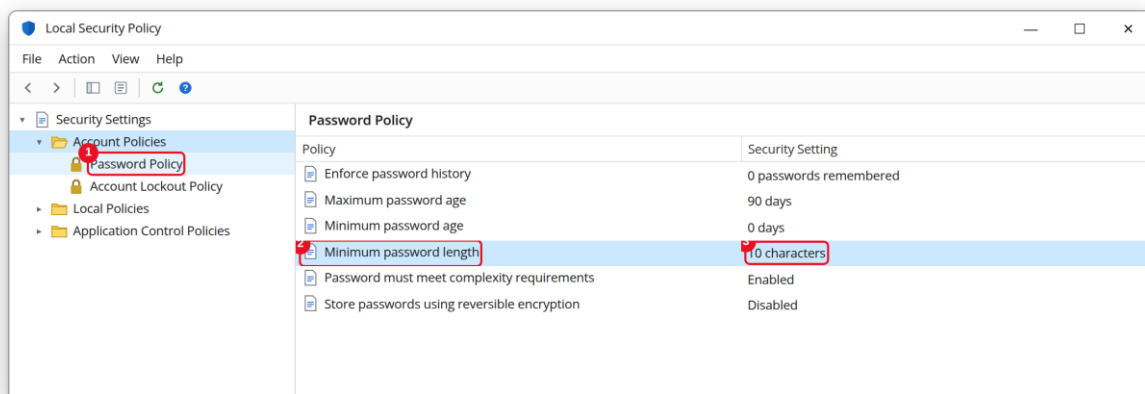


Figure 73. The Local Security Policy (secpol.msc) window

First, let us show exactly where these settings are opened. **Win** + **R** → **secpol.msc** → **Account Policies** → **Password Policy**. You change a value by double-clicking its row:



① secpol.msc → Account Policies → Password Policy

② Double-click any row to change its value

Figure 74. secpol.msc → Account Policies → Password Policy (annotated)

For example, double-clicking the “Minimum password length” row opens the following small window — this is where you enter the minimum number of characters:

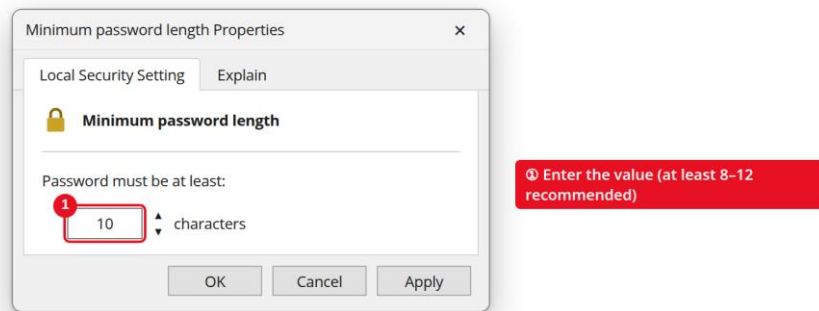


Figure 75. The “Minimum password length” properties window

1.1. Account Policies

This section defines the rules for passwords and account lockout. Recommended values for a secure system:

Setting	Recommended value	Purpose
Minimum password length	At least 8–12 characters	Prevents short, easily guessed passwords
Password must meet complexity requirements	Enabled	Requires upper/lower-case letters, digits and symbols in the password
Maximum password age	60–90 days	Forces the password to be changed regularly
Account lockout threshold	3–5 invalid attempts	Protects against password-guessing (brute-force) attacks
Account lockout duration	15–30 minutes	Sets how long a locked account stays locked

Why does password policy matter?

- If a password is only 6 characters long, an automated guessing (brute-force) attack can find it within a few hours.
- Finding a 12-character password made of upper/lower-case letters, digits and symbols is practically impossible.
- Account lockout stops such attempts after 3–5 tries, making the attack completely useless.

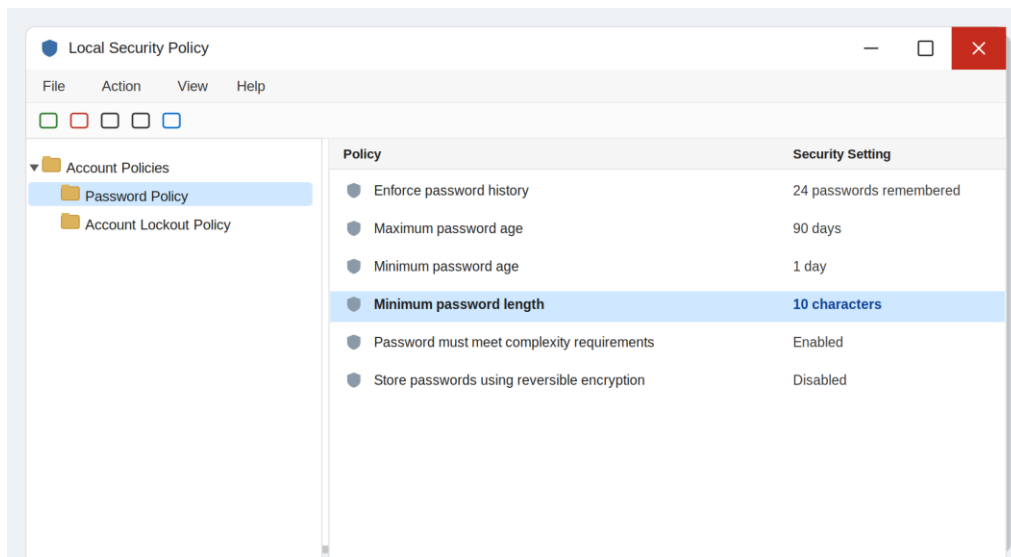


Figure 76. Account Policies → Password Policy settings (secpol.msc)

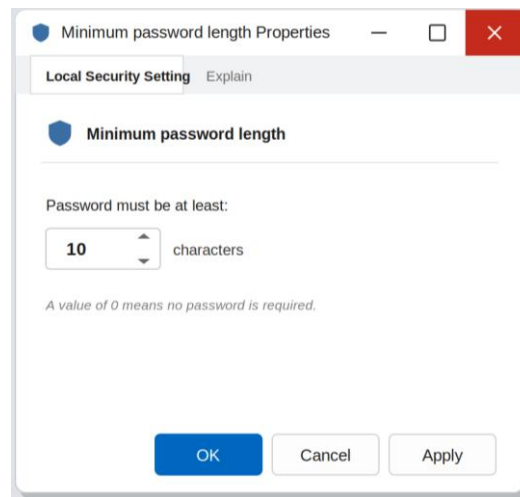


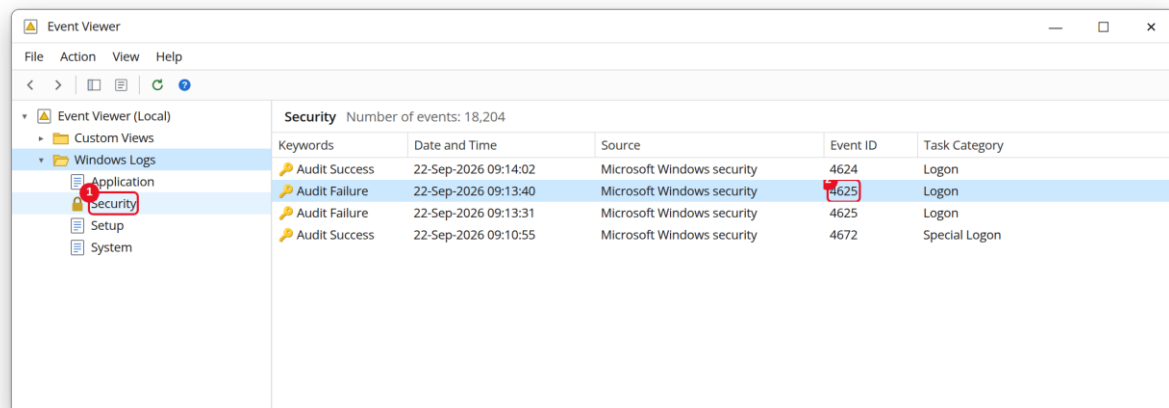
Figure 77. The “Minimum password length” properties window

1.2. Local Policies — Audit and Security Options

The Audit Policy defines which events on the system (login attempts, file access, changes to settings) are recorded in the Windows Event Log. This serves as the data source for cyber forensics and SIEM systems, which are studied in later topics. The Security Options section contains important settings such as:

3. **Interactive logon: Do not display last user name** — hides the name of the last signed-in user on the login screen, which makes it harder for an attacker to guess an account name.
4. **Accounts: Rename administrator account** — changing the default “Administrator” name, because this name is known to attackers in advance.
5. **Accounts: Guest account status** — disabling the guest account, because it is often passwordless or weakly protected.

Where can you see the events recorded by the Audit Policy? — `eventvwr.msc` (Event Viewer) → **Windows Logs** → **Security**. Every login attempt is recorded here. For example **Event ID 4625** — a failed login (a sign of a password-guessing attack):



④ eventvwr.msc → Windows Logs → Security. Events recorded by the Audit Policy are here

④ Event ID 4625 = failed logon (a sign of password guessing)

Figure 78. Event Viewer → Security log — logon events (annotated)



Figure 79. How a password-guessing attack appears in the Security log

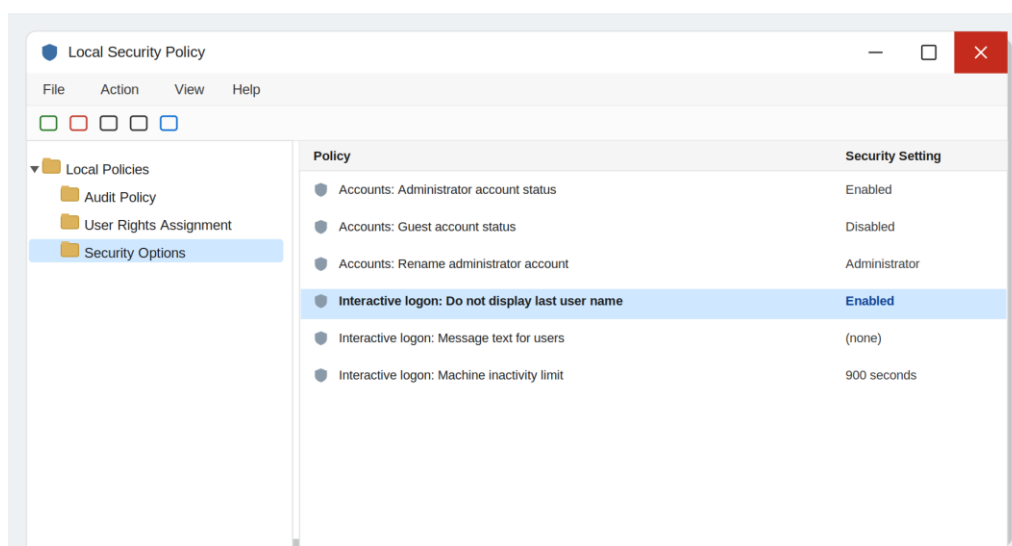


Figure 80. The Local Policies → Security Options list

1.3. Practical task: changing a security setting

1. **Win** + **R** → run the `secpol.msc` command.
2. Go to Account Policies → Password Policy.

3. Change the “Minimum password length” value to 10.
4. Go to Local Policies → Security Options.
5. Find the “Interactive logon: Do not display last user name” setting and set it to “Enabled”.
6. Save the changes, lock the computer (**Win** + **L**) and check the result — the user name should no longer appear on the login screen.

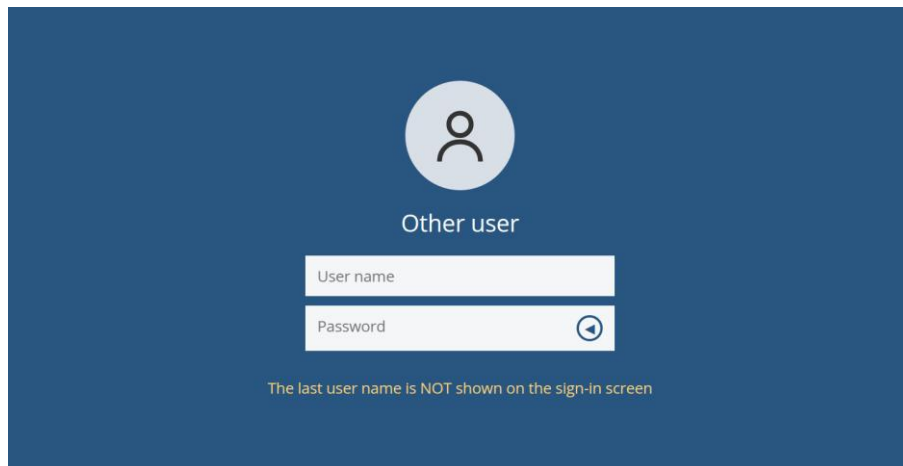
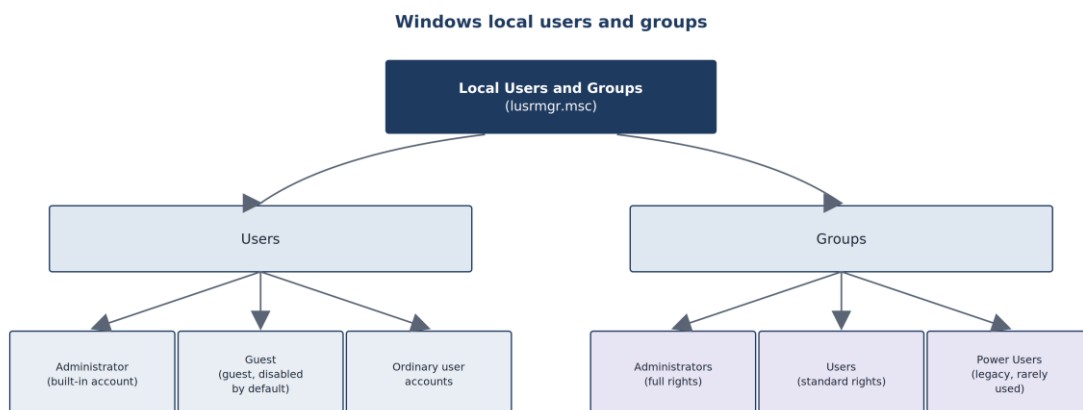


Figure 81. Result: the last user name is not shown on the sign-in screen

Question 2. Configuring user security

In Windows, a separate account is created for each person, and these accounts are combined into groups. Group membership determines what rights a user gets — this approach is called “role-based access control”.



*Practical rule: give each user only the minimum rights needed for their work
(the least privilege principle).*

Figure 82. Windows local users and groups

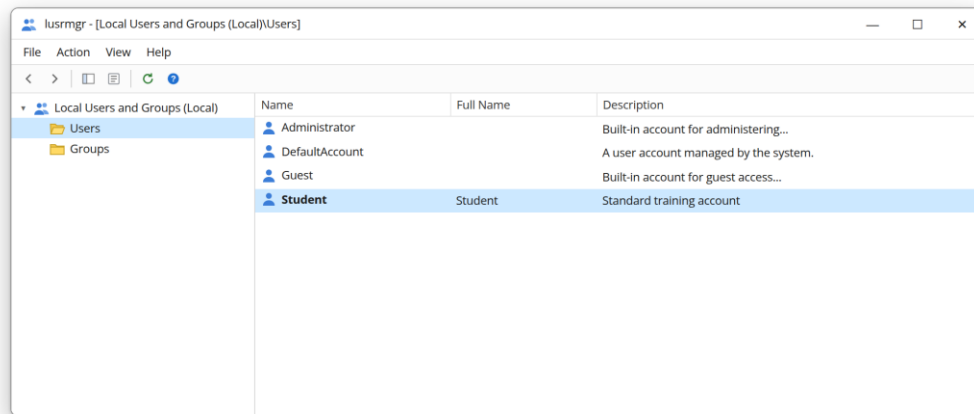
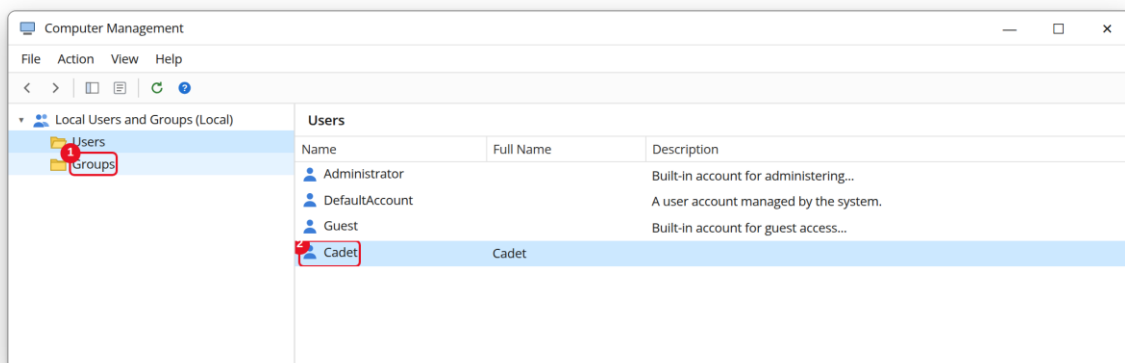


Figure 83. lusrmgr.msc — Local Users and Groups (user list)

Where are users and groups managed? — **Win** + **R** → **lusrmgr.msc** (Local Users and Groups). “Users” — accounts, “Groups” — groups:



lusrmgr.msc → Users / Groups. Every user and group is here

Figure 84. lusrmgr.msc — Local Users and Groups (users)

To create a new account through the GUI, right-click “Users” → “New User”. In the window that opens, only “User name” is required:

User name: Student

Full name:

Description:

Password:

Confirm password:

☒ User must change password at next logon

☐ User cannot change password

☐ Password never expires

☐ Account is disabled

Help Create Close

GUI method: Users → right-click → New User. User name is required, the rest is optional

Figure 85. Creating a new account through the “New User” window

From the command line the same job is done as follows. Note: the new account has “Local Group Memberships: *Users” — that is, it received standard (limited) rights:

```

Administrator: Command Prompt
PS C:\Windows\system32> net user Student Pass@2026 /add
The command completed successfully.

PS C:\Windows\system32> net localgroup Users Student /add
The command completed successfully.

PS C:\Windows\system32> net user Student
User name                Student
Full Name
Account active            Yes
Account expires           Never
Password last set        9/22/2026 10:14:02 AM
Local Group Memberships  *Users
Global Group memberships *None
The command completed successfully.

PS C:\Windows\system32>

```

net user ... /add — a new account. Local Group Memberships: *Users — standard (limited) rights

Figure 86. net user — creating and checking a new account

Group	Rights level	Recommendation
Administrators	Full — can change all system settings	Give only to people who perform administrator duties
Users	Standard — cannot install programs or change system settings	Recommended for everyday work accounts
Guests	Very limited, temporary	Keep disabled whenever possible

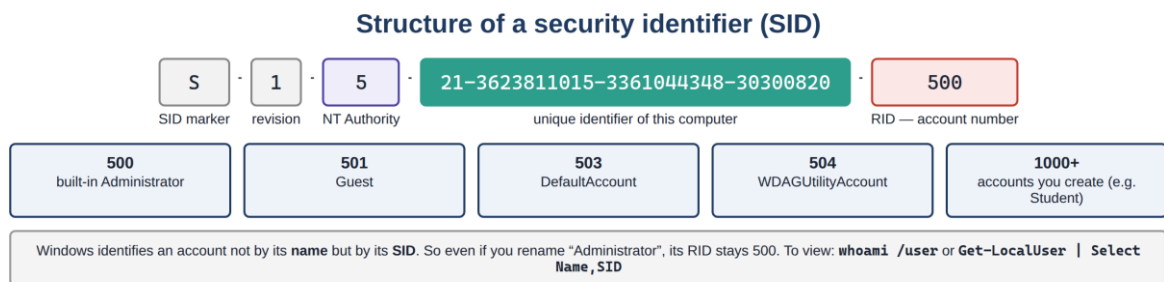


Figure 87. Structure of a security identifier (SID)

2.1. Practical task: creating a new limited user

This can be done through the GUI (Computer Management → Local Users and Groups) or from the command line. The command-line method:

Figure 88. GUI method: creating an account through the “New User” window

Command	What it does
<code>net user Student Pass@2026 /add</code>	Creates a new account named “Student” with the given password
<code>net localgroup Users Student /add</code>	Adds the new account to the standard “Users” group (usually automatic)
<code>net localgroup Administrators Student /delete</code>	If the account is accidentally in the Administrators group, removes it
<code>net user Student /active:yes</code>	Activates the account
<code>net user Student</code>	Shows full information about the account (groups, last login, etc.)

```

C:\Windows\system32> net user Student Pass@2026 /add
The command completed successfully.

C:\Windows\system32> net localgroup Users Student /add
The command completed successfully.

C:\Windows\system32> net user Student
User name                Student
Full Name                Student
Account active           Yes
Account expires           Never
Password last set        21/09/2026 10:14:02
Local Group Memberships  *Users
Global Group memberships *None
The command completed successfully.

C:\Windows\system32> _

```

Figure 89. Command line — creating and checking an account with “net user”

1. Create a new user account with standard rights using the net user command above.
2. Sign in again with the new account (Sign out → choose the new account).

3. Under this account, try to install a program or change a system setting — observe that the UAC Credential prompt (asking for a user name + password) appears.
4. Return to the administrator account and delete the test account with the net user Student /delete command.

Final security recommendations (checklist)

- Always use a standard account (in the Users group) for everyday work; use the Administrator account only when necessary.
- Disable the Guest account and rename the default Administrator account.
- Never set UAC to “Never notify”.
- Always keep AppLocker, or at least SmartScreen, turned on.
- Make the password policy (length, complexity, age) mandatory and enable Account Lockout.
- Never turn off Windows Defender and the Firewall; even if a third-party antivirus is installed, keep checking their status.

Frequently asked questions — Lesson 4

Q: The password policy I changed in secpol.msc does not work?

A: A local policy can be overridden by the domain’s Group Policy (GPO) — in a domain, the GPO takes precedence. On a standalone (non-domain) computer, the change takes effect immediately.

Q: Why is it dangerous to do everyday work in an administrator account?

A: Because malware that is accidentally launched immediately gets full admin rights as well. Use a standard account in the “Users” group for everyday work.

Q: How do I delete the account I created for testing?

A: As administrator: `net user Student /delete` or in lusrmgr.msc right-click the account → Delete.

Q: What is “role-based access control” in plain words?

A: Giving rights not to each person separately, but to a **group** (role). When you add a user to the right group, they get all the rights of that group.

Review questions — Lesson 4

1. What do the Account lockout threshold and Account lockout duration settings mean?
2. Why does the “Do not display last user name” setting increase security?
3. Explain the difference between the Administrators, Users and Guests groups.
4. Explain what the net user and net localgroup commands do.

5. Why is it recommended not to use an administrator account for everyday work?
6. Explain the concept of “role-based access control” in your own words.

Conclusion

This topic examined, step by step, the main mechanisms that secure the Windows operating system: first the background processes — services — and their privilege system (Lesson 1), then the tools that control user actions and programs — UAC, AppLocker, SmartScreen, Defender, Firewall (Lesson 2), and then the practical application of this knowledge — setup and configuration (Lessons 3 and 4).

This knowledge is not only valuable on its own, but is also an essential foundation for the following topics of the course — virology, network monitoring systems (SIEM, IDS/IPS) and ethical hacking (Metasploit, privilege escalation). In particular, according to the roadmap in the `roadmap.html` file, this topic corresponds directly to “Stage 02: Operating systems — in depth”, and also lays the groundwork for “Stage 05: Security fundamentals” and “Stage 08: Defense (Blue Team)”.

Glossary

Below is a short explanation of all the important terms that appear in this topic. Technical terms are kept in their original English form, so you will recognize them in English sources in the future.

Term	Meaning
Service	A program that runs in the background with no window on screen. It can start automatically when Windows boots and run under a special system account.
Service Control Manager (SCM)	The central component that manages all services (services.exe). Every service command passes through it.
svchost.exe	A shared host process that runs several services together inside one process.
SYSTEM (LocalSystem)	The account with the highest local privilege in Windows — even more powerful than an administrator. Many system services run under this account.
LocalService / NetworkService	Low-privilege accounts for services. LocalService is anonymous on the network; NetworkService acts on the network as the computer account.
Startup type	The setting that defines when a service starts: Automatic, Automatic (Delayed), Manual, Disabled.
Persistence	The ability of malware to keep running after the computer restarts. Often achieved by registering itself as a new service.
Privilege escalation	A low-privileged attacker climbing to higher rights (for example SYSTEM) through a weakness in the system.
Unquoted service path	A vulnerability that arises when the path to a service file is unquoted and contains spaces (MITRE ATT&CK T1574.009).
Attack surface	The sum of all points an attacker could attack. Disabling unneeded services reduces it.
UAC (User Account Control)	A mechanism that asks for confirmation whenever an action requires admin rights. Present since Windows Vista.
Secure Desktop	The protected mode in which the UAC confirmation window is shown (the screen dims) — malware cannot click a fake button.
Consent prompt / Credential prompt	For an administrator — a simple “Yes/No” (Consent); for a standard user — an admin user name/password (Credential).
Integrity level	The trust level of processes (Low/Medium/High/System). UAC works based on these levels.
Filtered token / Full token	The two sets of rights given when an administrator signs in: a restricted (filtered) token for everyday work and a full token that is activated after confirmation.

Term	Meaning
Least privilege	The principle of giving each user/service only the minimum rights it needs.
AppLocker	An “allow list” (whitelist) mechanism that controls which programs may run. Full support only in the Enterprise/Education/Server editions.
Rule collection	The types of AppLocker rules: Executable, Windows Installer, Script, Packaged app, DLL.
Publisher / Path / File Hash	The three conditions an AppLocker rule can be based on: digital signature, file location, or the file’s “fingerprint”.
Application Identity (AppIDSvc)	The service that must be running for AppLocker to work.
SmartScreen	Protection that checks files and sites downloaded from the internet by their reputation.
Mark of the Web (Zone.Identifier)	A special mark added to a file downloaded from the internet — SmartScreen checks based on this mark.
Windows Defender	The antivirus/antimalware built into Windows. Actively scans files present on the system.
Real-time protection	The Defender component that checks every file immediately as it is opened or run.
Tamper Protection	A mechanism that protects Defender’s settings from being turned off by malware.
Controlled folder access	Protects important folders from unauthorized changes (for example ransomware).
Windows Firewall	The wall that controls incoming (Inbound) and outgoing (Outbound) network traffic of the computer.
Firewall profiles	Domain, Private, Public — sets of rules applied depending on the type of network.
Defense in depth	The principle of placing several layers of protection one after another: if one layer is breached, the next one stops the attack.
Local Security Policy (secpol.msc)	The console that gathers security settings such as password, audit and user-rights settings.
Group Policy (gpedit.msc / GPO)	A tool for managing settings centrally; in a domain it is applied through Active Directory GPOs.
LSDOU	The order in which group policies are applied: Local → Site → Domain → OU.
Account lockout	Temporarily locking an account after several wrong password attempts — protection against brute-force attacks.

Term	Meaning
Password complexity	A rule requiring upper/lower-case letters, digits and symbols in a password.
SID (Security Identifier)	The unique numeric identifier of every user and group in the system.
Role-based access control (RBAC)	The approach of giving rights to a group (role) rather than to an individual.
MMC / .msc	Microsoft Management Console — a common frame for management windows; .msc is a ready-made console file.
Audit Policy / Event ID	The policy that defines which events are written to the log; Event ID is the number of an event type (for example 4625 — a failed login).

References and sources

Official documentation (Microsoft)

7. Service Control Manager — <https://learn.microsoft.com/en-us/windows/win32/services/service-control-manager>
8. About Services (Win32 apps) — <https://learn.microsoft.com/en-us/windows/win32/services/about-services>
9. Windows System Services Fundamentals — <https://learn.microsoft.com/en-us/archive/technet-wiki/12229.windows-system-services-fundamentals>
10. Get-Service / Start-Service / Stop-Service / Set-Service (PowerShell) — <https://learn.microsoft.com/en-us/powershell/module/microsoft.powershell.management/get-service>
11. How User Account Control works — <https://learn.microsoft.com/en-us/windows/security/application-security/application-control/user-account-control/how-it-works>
12. AppLocker overview — <https://learn.microsoft.com/en-us/windows/security/application-security/application-control/app-control-for-business/applocker/applocker-overview>
13. Microsoft Defender SmartScreen overview — <https://learn.microsoft.com/en-us/windows/security/operating-system-security/virus-and-threat-protection/microsoft-defender-smartscreen/>
14. Microsoft Defender Antivirus in Windows overview — <https://learn.microsoft.com/en-us/defender-endpoint/microsoft-defender-antivirus-windows>

15. Windows Defender Firewall with Advanced Security (Explore) —
<https://learn.microsoft.com/en-us/training/modules/manage-defender-windows-client/6-explore-windows-defender-firewall-advanced-security>

Sources on security practice and attack techniques

16. MITRE ATT&CK — T1574.009: Hijack Execution Flow: Path Interception by Unquoted Path — <https://attack.mitre.org/techniques/T1574/009/>
17. HackTricks — Windows Local Privilege Escalation Checklist —
<https://hacktricks.wiki/en/windows-hardening/checklist-windows-privilege-escalation.html>

Core literature recommended by the department

18. Nishanov I.I., Xusenov M.J. — Cyber Forensics and Ethical Hacking: textbook. Tashkent, 2024. — 390 p.
19. Brian W. Kernighan. Understanding the Digital World: What You Need to Know about Computers, the Internet, Privacy, and Security, 2nd Edition. 2022.